

Sri Lanka Institute of Information Technology



Individual Assignment

Bug Bounty Reports

Ayeshani K. M. N.

Web Security - IE2062

B.Sc. (Hons) in Information Technology

CASE STUDY NAME	10 Bug Bounty Reports
------------------------	------------------------------

Web Security - IE2062**Year 2 Semester 2 - 2023****Contents**

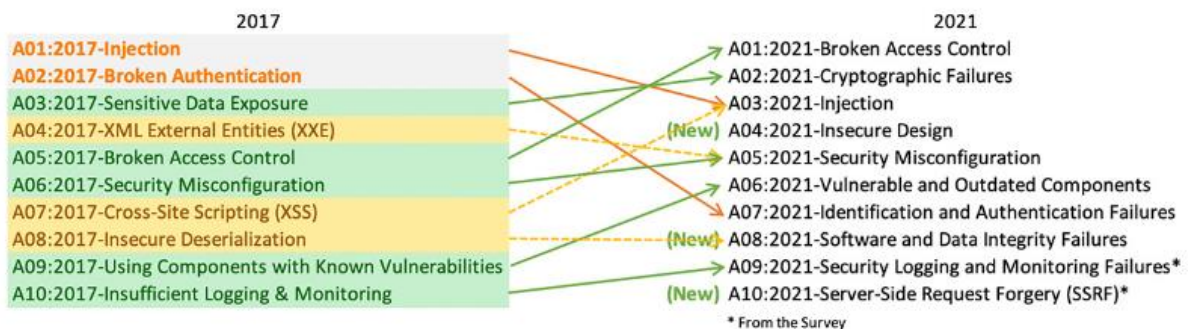
What is OWSAP top 10 Vulnerabilities?.....	4
The OWASP Rating Methodology	8
Report 01.....	11
Report 02.....	21
Report 03.....	28
Report 04.....	35
Report 05.....	42
Report 06.....	48
Report 07.....	53
Report 08.....	57
Report 09.....	62
Report 10.....	67

What is OWASP top 10 Vulnerabilities?

The OWASP Top 10 Vulnerabilities is a compilation of the most critical security risks commonly encountered in web applications. This was developed by the Open Web Application Security Project (OWASP), which is a non-profit organization focused on web application security. For developers, security experts, and organizations looking to prioritize and address serious security concerns, this vulnerability list is a useful resource. The OWASP Top 10 Vulnerabilities list is derived from extensive research, community input, real-world analysis, code reviews, penetration testing, and security research. Although not all-inclusive, these vulnerabilities show widespread problems that pose serious threats to online applications. Developers can create more secure online apps, businesses may strengthen their security posture, and consumers can have better faith in the security of the systems they use by understanding and tackling the OWASP top 10 vulnerabilities.

The OWASP Top - ten is indeed a generally acknowledged list which ranks those best ten cyber threats impacting online applications. Even if there are more than 10 security dangers in applications, the goal of the OWASP List of top is to ensure ethical hackers knowledgeable along with at minimum a more significant security threats as well as teach individuals importance of being able protect over threats. This list will be updated eventually year by year. By visiting this site <https://owasp.org/www-project-top-ten/> we can observe the list updated frequently

Here is a comparison between 2021 and 2017 vulnerabilities.



Web Security - IE2062**Year 2 Semester 2 - 2023**

This report contains the bugs regarding the below vulnerabilities.

1. Injection
2. Broken Authentication
3. Sensitive Data Exposure
4. XML External Entities (XXE)
5. Broken Access Control
6. Security Misconfiguration
7. Cross-Site Scripting (XSS)
8. Insecure Deserialization
9. Using Components with Known Vulnerabilities
10. Insufficient Logging and Monitoring

Web Security - IE2062**Year 2 Semester 2 - 2023**

Here are the brief explanations about OWSAP top 10 vulnerabilities in 2017.

1. Injection:

Injection can happen when untrusted data is processed as a command or query without being properly verified. Attackers might take advantage of these flaws to modify data, execute malicious code, or obtain unauthorized access.

2. Broken Authentication and Session Management:

Unauthorized access to user accounts or session hijacking can originate from flaws in authentication and session management. Attackers may take advantage of weaknesses in password management, session IDs, or logout methods.

3. Cross-Site Scripting (XSS):

XSS vulnerabilities allow attackers to inject malicious scripts into web pages viewed by other users. This can lead to the theft of sensitive information, session hijacking, or defacement of websites.

4. Insecure Direct Object References:

When application functionality relies on user-supplied input to access objects directly, without proper authorization checks, it can lead to insecure direct object references. Attackers can manipulate parameters to access unauthorized data or functionality.

5. Security Misconfiguration:

Security misconfigurations occur when systems or frameworks are not properly configured, leaving them vulnerable to attacks. This includes default configurations, error messages, or unnecessary features that can be exploited.

6. Sensitive Data Exposure:

When sensitive data, such as credit card numbers or personal information, is not properly protected, it can be accessed by unauthorized users. Inadequate encryption, weak authentication, or storage of sensitive data can result in its exposure.

7. Missing Function Level Access Control:

If access control checks are not implemented at the correct function level, attackers can bypass authorization and gain unauthorized access to privileged functionality or data.

8. Cross-Site Request Forgery (CSRF):

CSRF vulnerabilities allow attackers to trick users into unknowingly executing malicious actions on their behalf. By exploiting trust between the user and the application, attackers can perform actions like changing passwords or making unauthorized transactions.

9. Using Components with Known Vulnerabilities:

Many applications use third-party components or libraries. If these components have known vulnerabilities and are not properly updated, attackers can exploit those weaknesses to gain unauthorized access or execute malicious code.

10. Unvalidated Redirects and Forwards:

When applications redirect or forward users to different pages without proper validation, attackers can manipulate the URLs to redirect users to malicious websites or trick them into performing unintended actions.

It is crucial for developers and organizations to address these vulnerabilities through secure coding practices, regular updates, and proper security configurations to protect web applications from potential exploits and attacks.

The OWASP Rating Methodology

OWASP (Open Web Application Security Project) provides a widely recognized and respected framework for assessing and rating the security level of web applications.

Security experts are able to evaluate the security posture of online applications using the OWASP Rating Methodology, which is a collection of principles. It attempts to encourage a standardized approach to security assessment and provide businesses the tools they need to efficiently detect and mitigate any risks.

The OWASP Rating Methodology consists of the following key components.

1. **Application profile** - This involves gathering details about the online application, such as its function, technological stack, and goal. It is essential to comprehend the architecture and components of the program before evaluating its security.
2. **Threat Profile** - The threat profile identifies possible dangers and weaknesses to which the web application may be exposed. Cross-site scripting (XSS), SQL injection, unsecured direct object references, and other widespread security risks are identified, and their applicability to the application is evaluated.
3. **Security Conditions** - Specifying security conditions aids in determining the required level of protection for a website application. In doing so, it is necessary to identify the degree of security required for various assets, including user data, confidential data, methods of authentication, and the system.
4. **Conducting security checks and examining the web application's vulnerabilities** are part of the evaluation step. It uses a variety of methods, including manual code reviews, dynamic application scanning, static code analysis, and penetration testing. The assessment's goal is to find any application flaws and vulnerabilities that could be present.
5. **Risk Assessment** - Each identified vulnerability is assessed for its possibility and effect. The impact analysis considers possible outcomes, including data breaches, monetary losses, reputational harm, and regulatory non-compliance. The likelihood assessment calculates the possibility that an attacker will successfully exploit the vulnerability.
6. **Risk Treatment** - Following the identification and evaluation of the vulnerabilities, the risk management stage focuses on choosing the most effective ways to reduce or completely eradicate the risks. Applying security controls include making adjustments

Web Security - IE2062**Year 2 Semester 2 - 2023**

to code, configuration, access restrictions, input validation, and security awareness training.

7. Rating - The OWASP Rating Methodology gives a rating system to evaluate the web application's general level of security. A numerical scale, a hierarchy of levels (such as low, medium, and high), or a combination of criteria may be used to determine the rating. Organizations may use the grade to determine which security enhancements should be prioritized and how secure an application is.

Organizations may systematically assess the security of their online applications, find vulnerabilities, and take the necessary steps to improve security by adhering to the OWASP Rating Methodology.

Here is an extract from [https://owasp.org/www-community/OWASP Risk Rating Methodology](https://owasp.org/www-community/OWASP_Risk_Rating_Methodology)

Likelihood and Impact Levels	
0 to <3	LOW
3 to <6	MEDIUM
6 to 9	HIGH

Web Security - IE2062
Year 2 Semester 2 - 2023

"Threat agent factors"					"Vulnerability factors"			
Skill level	Motive	Opportunity	Size		Ease of discovery	Ease of exploit	Awareness	Intrusion detection
5	2	7	1		3	6	9	2
Overall likelihood=4.375 (MEDIUM)								

Technical Impact					Business Impact			
Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability		Financial damage	Reputation damage	Non-compliance	Privacy violation
9	7	5	8		1	2	1	5
Overall technical impact=7.25 (HIGH)					Overall business impact=2.25 (LOW)			

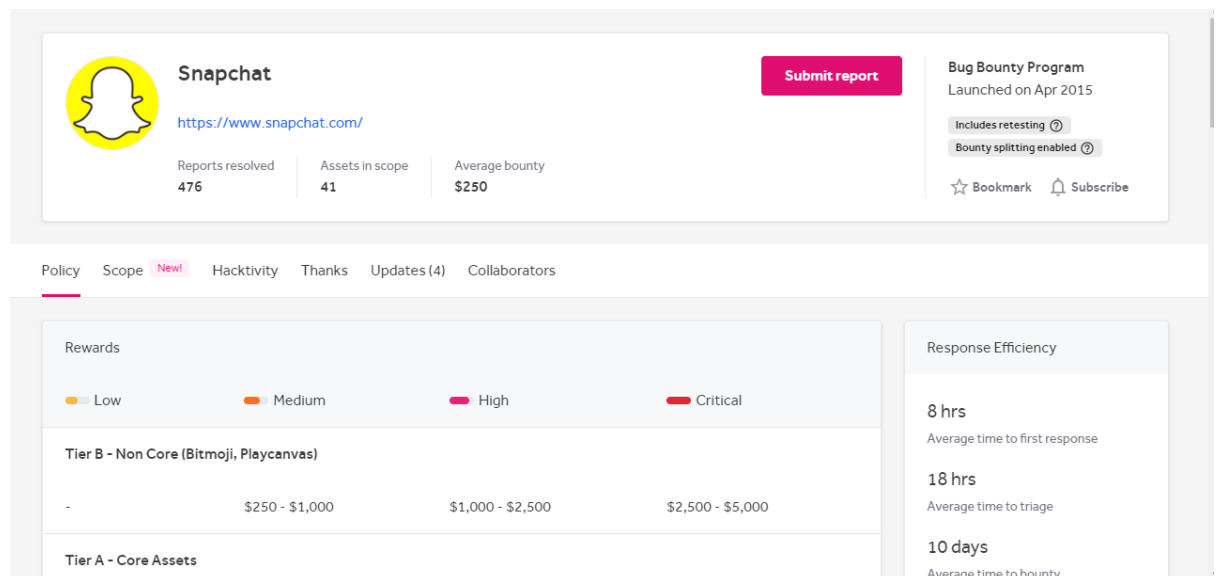
Report 01

- **Vulnerability title** - Weak Ciphers Enabled
- **Owsap vulnerability**- Security misconfiguration.
- **Vulnerability description** - The security and confidentiality of data during transmission are significantly at risk due to the "Weak Cypher Enabled" issue. A secure communication system must include encryption cyphers because they guard confidential data against theft and alteration. However, enabling weak cyphers exposes networks and systems to the risk of being used by intruders.

A weak cypher is an encryption algorithm that is insecure or out-of-date and lacks the requisite power to fend off contemporary cryptographic assaults. Due to these poor cyphers' ease of use, attackers are able to alter transmitted data, perform man-in-the-middle attacks, and intercept and decode sensitive data.

Misconfigurations in system settings, web server setups, or network device configurations frequently give conception to this vulnerability. In rare circumstances, obsolete installations or default settings may unintentionally enable weak cyphers

- **Affected components** – <https://www.snapchat.com/>



The screenshot shows the Snapchat Bug Bounty Program page. At the top, there's a header with the Snapchat logo, the URL <https://www.snapchat.com/>, and a 'Submit report' button. Below this, statistics are shown: Reports resolved (476), Assets in scope (41), and Average bounty (\$250). To the right, it mentions the 'Bug Bounty Program' launched on Apr 2015, with features like 'Includes retesting' and 'Bounty splitting enabled'. There are also 'Bookmark' and 'Subscribe' options.

Below the header, there's a navigation bar with links: Policy, Scope, **New!**, Hacktivity, Thanks, Updates (4), and Collaborators.

The main content area is divided into two sections. The left section is titled 'Rewards' and shows a table of bounty tiers. The right section is titled 'Response Efficiency' and shows the average time to first response, average time to triage, and average time to bounty.

Rewards	Low	Medium	High	Critical
Tier B - Non Core (Bitmoji, Playcanvas)	-	\$250 - \$1,000	\$1,000 - \$2,500	\$2,500 - \$5,000
Tier A - Core Assets				

Response Efficiency
8 hrs Average time to first response
18 hrs Average time to triage
10 days Average time to bounty

Web Security - IE2062
Year 2 Semester 2 - 2023

The following domains are in scope.

Tier B - Non Core (Bitmoji, Playcanvas)	Other	In scope	Medium	Eligible
accounts.snapchat.com [Core asset] Snapchat's account management website.	Domain	In scope	Critical	Eligible
ads.snapchat.com	Domain	In scope	High	Eligible
app.snapchat.com [Core asset] Main server-side application hosted on Google App Engine under the hostname feelinsonice-hrd.appspot.com and app.snapchat.com.	Domain	In scope	Critical	Eligible
blog.playcanvas.com	Domain	In scope	Medium	Eligible
business.snapchat.com Snapchat's Business Manager.	Domain	In scope	Critical	Eligible
businesshelp.snapchat.com Snapchat's Salesforce instance	Domain	In scope	High	Eligible
code.playcanvas.com	Domain	In scope	Medium	Eligible
com.bitstrips.imoji [Non-core asset][Google Play Store](https://play.google.com/store/apps/details?id=com.bitstrips.imoji)	Android: Play Store	In scope	Medium	Eligible

- Impact assessment** - A system or network may experience major security risks if weak cyphers are enabled. Sensitive data is subject to breaches due to weak cyphers, which are encryption algorithms or protocols that are defective or easily exploited. Enabling weak cyphers has the effect of allowing unauthorized access to data and compromising its secrecy, integrity, and validity. Sensitive information may be intercepted and deciphered by attackers, which might result in data disclosure, identity theft, and financial fraud. Systems vulnerable to man-in-the-middle attacks, where hackers can manipulate or eavesdrop on communication unnoticed, are also caused by weak cyphers. Additionally, weak cyphers make it easier to crack credentials and passwords, put users at risk for compliance and legal issues, and expose them to denial-of-service threats.
- Steps to reproduce –**
 1. Recognize the Target: Decide the network or system you wish to examine for weak cypher vulnerabilities. To do security testing, make sure you have the necessary authority and legal permits.
 2. Discover the Encryption Protocols: Do some research and discover the encryption protocols that the target network or system uses. For secure communication, SSL/TLS are popular protocols.

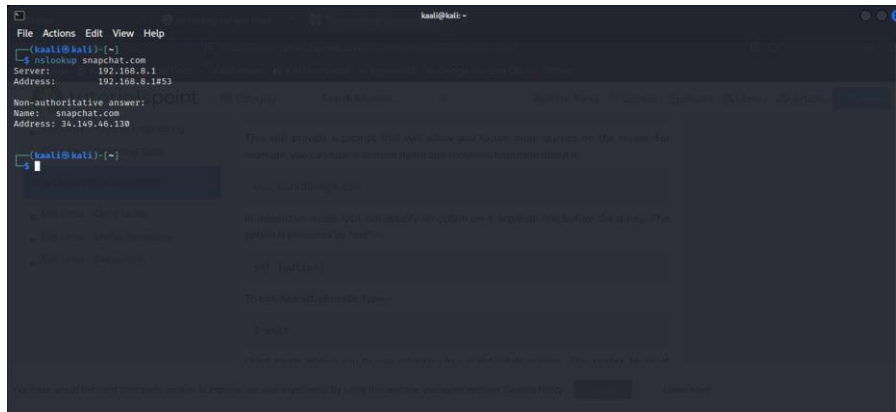
Web Security - IE2062**Year 2 Semester 2 - 2023**

3. **Analyze Current Cypher Configuration:** Discover the target's present cypher suite configuration. Frequently, this information may be found in the system manual or by employing network scanning software or utilities like OpenSSL.
4. **Identify Weak Cyphers:** Conduct research on the target system and develop a list of known weak cyphers or insecure encryption techniques. Older versions of the SSL/TLS protocols or encryption methods with known security flaws are frequent examples.
5. **Disable Secure Cypher Suites:** Make changes to the target machine or network's settings to disable secure cypher suites. On a production system should not be used for this; only a controlled testing environment should be used.
6. **Test for Vulnerability:** Check the target system for the presence of weak cypher suites using security testing tools as SSL scanners, network analyzers, or custom scripts. These tools will reveal the presence of any vulnerable cyphers and give information on the flaws.
7. **Record and Report Findings:** List any other pertinent data or suggestions together with the found weak cyphers and associated vulnerabilities. Write out a thorough report describing the results and possible effects of the weak cypher enabled vulnerability.
8. **Suggestions for reducing Weak Cypher Vulnerabilities:** Include suggestions on how to mitigate the weak cypher vulnerability, such as enabling safe and current cypher suites, putting the required fixes in place, or changing encryption methods.
9. **Report and Follow-Up:** Inform the system or network administrators or other accountable parties about the vulnerability. Explain the dangers posed by the weak cypher vulnerability and help apply the suggested corrective measures.

Web Security - IE2062

Year 2 Semester 2 - 2023

- Proof of concept (if applicable) –



2. Weak Ciphers Enabled

MEDIUM 1

CONFIRMED 1

Netsparker detected that weak ciphers are enabled during secure communication (SSL).

You should allow only strong ciphers on your web server to protect secure communication with your visitors.

Impact

Attackers might decrypt SSL traffic between your server and your visitors.

Vulnerabilities

2.1. <https://www.snapchat.com/>

CONFIRMED

0
0
2
4
6
12

Web Security - IE2062

Year 2 Semester 2 - 2023

Scanned using ssl scan.

```
(root@DESKTOP-U4KH917) - [ /home/kali/knock ]
# sslscan

Common name
2.0.15-static
OpenSSL 1.1.1q-dev xx XXX xxxx

Organisation
State
Country
California
United States

Command:
sslscan [options] [host:port | host]

Options:
--targets=<file> A file containing a list of hosts to check.
--sn1-name=<name> Hostname for SNI
--ipv4, -4 Only use IPv4
--ipv6, -6 Only use IPv6
--show-certificate Show full certificate information
--show-client-cas Show trusted CAs for TLS client auth
--no-check-certificate Don't warn about weak certificate algorithm or keys
--ocsp Request OCSP response from server
--pk=<file> A file containing the private key or a PKCS#12 file
--pkpass=<password> The password for the private key or PKCS#12 file
--certs=<file> A file containing PEM/ASN1 formatted client certificates
--ssl2 Only check if SSLv2 is enabled
--ssl3 Only check if SSLv3 is enabled
--tls10 Only check TLSv1.0 ciphers
--tls11 Only check TLSv1.1 ciphers
--tls12 Only check TLSv1.2 ciphers
--tls13 Only check TLSv1.3 ciphers
--tlsall Only check TLS ciphers (all versions)
--show-ciphers Show supported client ciphers
--show-cipher-ids Show cipher ids
--iana-names Use IANA/RFC cipher names rather than OpenSSL ones
--show-times Show handshake times in milliseconds
--no-cipher-details Disable EC curve names and EDH/RSA key lengths output
--no-ciphersuites Do not check for supported ciphersuites
--no-compression Do not check for TLS compression (CRIME)
--no-fallback Do not check for TLS Fallback SCSV
--no-groups Do not enumerate key exchange groups
--no-heartbleed Do not check for OpenSSL Heartbleed (CVE-2014-0160)
--no-renegotiation Do not check for TLS renegotiation
--show-sigs Enumerate signature algorithms
--starttls-ftp STARTTLS setup for FTP
--starttls-imap STARTTLS setup for IMAP
--starttls-irc STARTTLS setup for IRC
--starttls-ldap STARTTLS setup for LDAP
--starttls-mysql STARTTLS setup for MySQL
--starttls-pop3 STARTTLS setup for POP3
--starttls-psql STARTTLS setup for PostgreSQL
--starttls-smtp STARTTLS setup for SMTP
--starttls-xmpp STARTTLS setup for XMPP
```

Web Security - IE2062

Year 2 Semester 2 - 2023

```

--bugs          Enable SSL implementation bug work-arounds
--no-colour     Disable coloured output
--sleep=<msec>  Pause between connection request. Default is disabled
--timeout=<sec> Set socket timeout. Default is 3s
--connect-timeout=<sec> Set connect timeout. Default is 75s
--verbose      Display verbose output
--version      Display the program version
--xml=<file>   Output results to an XML file. Use - for STDOUT.
--help        Display the help text you are now reading

Example:
sslsan 127.0.0.1
sslsan [::1]

(root@DESKTOP-U4KH917)-[/home/kali/knock]
# sslscan https://www.snapchat.com
Version: 2.0.15-static
OpenSSL 1.1.1q-dev xx XXX xxxx
Connected to 34.149.46.130

Testing SSL server www.snapchat.com on port 443 using SNI name www.snapchat.com

SSL/TLS Protocols:
SSLv2 disabled
SSLv3 disabled
TLSv1.0 enabled
TLSv1.1 enabled
TLSv1.2 enabled
TLSv1.3 enabled

TLS Fallback SCSV:
Server supports TLS Fallback SCSV

TLS renegotiation:
Secure session renegotiation supported

TLS Compression:
Compression disabled

Heartbleed:
TLSv1.3 not vulnerable to heartbleed
TLSv1.2 not vulnerable to heartbleed
TLSv1.1 not vulnerable to heartbleed
TLSv1.0 not vulnerable to heartbleed

Supported Server Cipher(s):
Preferred TLSv1.3 128 bits TLS_AES_128_GCM_SHA256 Curve 25519 DHE 253
Accepted TLSv1.3 256 bits TLS_AES_256_GCM_SHA384 Curve 25519 DHE 253
Accepted TLSv1.3 256 bits TLS_CHACHA20_POLY1305_SHA256 Curve 25519 DHE 253
Preferred TLSv1.2 256 bits ECDHE-RSA-CHACHA20-POLY1305 Curve 25519 DHE 253
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-GCM-SHA256 Curve 25519 DHE 253
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-GCM-SHA384 Curve 25519 DHE 253
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA Curve 25519 DHE 253
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-SHA Curve 25519 DHE 253
Accepted TLSv1.2 128 bits AES128-GCM-SHA256 Curve 25519 DHE 253
Accepted TLSv1.2 256 bits AES256-GCM-SHA384 Curve 25519 DHE 253
Accepted TLSv1.2 128 bits AES128-SHA Curve 25519 DHE 253
Accepted TLSv1.2 256 bits AES256-SHA Curve 25519 DHE 253
Accepted TLSv1.2 112 bits DES-CBC3-SHA Curve 25519 DHE 253
Preferred TLSv1.1 128 bits ECDHE-RSA-AES128-SHA Curve 25519 DHE 253
  
```

```

Server Key Exchange Group(s):
TLSv1.3 128 bits secp256r1 (NIST P-256) Protocol version
TLSv1.3 192 bits secp384r1 (NIST P-384) Public key length
TLSv1.3 128 bits x25519 Certificate check
TLSv1.2 128 bits secp256r1 (NIST P-256)
TLSv1.2 192 bits secp384r1 (NIST P-384)
TLSv1.2 128 bits x25519

SSL Certificate:
Signature Algorithm: sha256WithRSAEncryption Signature
RSA Key Strength: 2048 algorithm
Subject: *.snap.com
AltNames: DNS:*.snap.com, DNS:*.snapchat.com, DNS:*.ats.snapchat.com, DNS:*.snapads.com, DNS:*.snap-dev.net, DNS:*.snappcm.com, DNS:*.snappcm-dev.com, DNS:*.snapar.com, DNS:*.snapkit.com, DNS:snap.com, DNS:snapchat.com, DNS:ats.snapchat.com, DNS:snapads.com, DNS:snap-dev.net, DNS:snappcm.com, DNS:snappcm-dev.com, DNS:snapar.com, DNS:snapkit.com
Issuer: DigiCert Global G2 TLS RSA SHA256 2020 CA1
Not valid before: Apr 13 00:00:00 2023 GMT Version number
Not valid after: Apr 12 23:59:59 2024 GMT

Certificate Transparency
  
```


Web Security - IE2062

Year 2 Semester 2 - 2023

Here are the Knock.py results.

Web Security - IE2062

Year 2 Semester 2 - 2023

[illegible]

- **Proposed mitigation or fix-**

The following things here are some common mitigation steps that we can follow.

1. **Disable Weak Cyphers:** Check the setup of the cypher suite and turn off any ineffective or old encryption techniques. Only current encryption protocols that allow robust and secure cypher suites should be enabled.
2. **Maintain Software Updates:** Ensure that the frameworks, libraries, and programs utilised by system or network infrastructure are continually updated. By doing this, users may be certain that you get the most recent security upgrades, including updates for cypher vulnerabilities.
3. **Use Strong Encryption Algorithms:** Make use of encryption techniques that can withstand known cryptographic assaults. Select algorithms that are well-liked and advised by security professionals and standards bodies.
4. **Enable Perfect Forward Secrecy (PFS)** to guarantee that previous encrypted conversations remain safe even if a private key is compromised in the future.
5. **Regular Security Audits and Scans:** To find weak cypher vulnerabilities in your system, do routine security audits and vulnerability scans. To find and fix any found holes, use trusted security scanning tools and recommended practises.
6. **Implementing proper configuration management** will guarantee uniform and secure cypher suite configurations across all systems and applications. This may be done by maintaining a centralized configuration management procedure. Review and update the settings on a regular basis in accordance with industry best practises.
7. **Keep up with security warnings, flaws, and upgrades** affecting encryption algorithms and protocols by monitoring security advisories. Subscribe to security mailing lists and keep an eye on official sources to get alerts and advice as soon as they are available.
8. **Follow industry best practices :** Follow accepted security best practises, such as employing secure protocols (like TLS), for encryption and safe communication.
9. **Regularly Provide system administrators, developers, and other stakeholders** with training and awareness programs so they can manage and configure encryption methods. They should be made aware of secure cypher setups and the value of adhering to current encryption standards.

Web Security - IE2062**Year 2 Semester 2 - 2023**

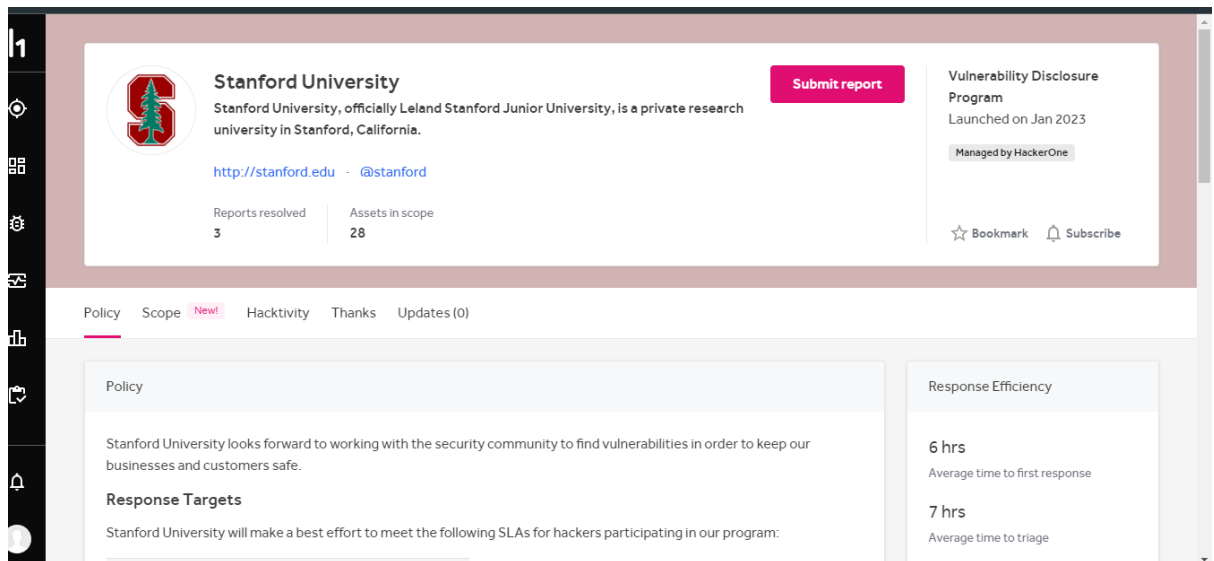
10. Conduct periodic penetration tests to evaluate the efficiency of security measures and spot any possible vulnerabilities in cypher and encryption setups. Hire experienced security testers to mimic actual attack scenarios and offer recommendations for improvement

Report 02

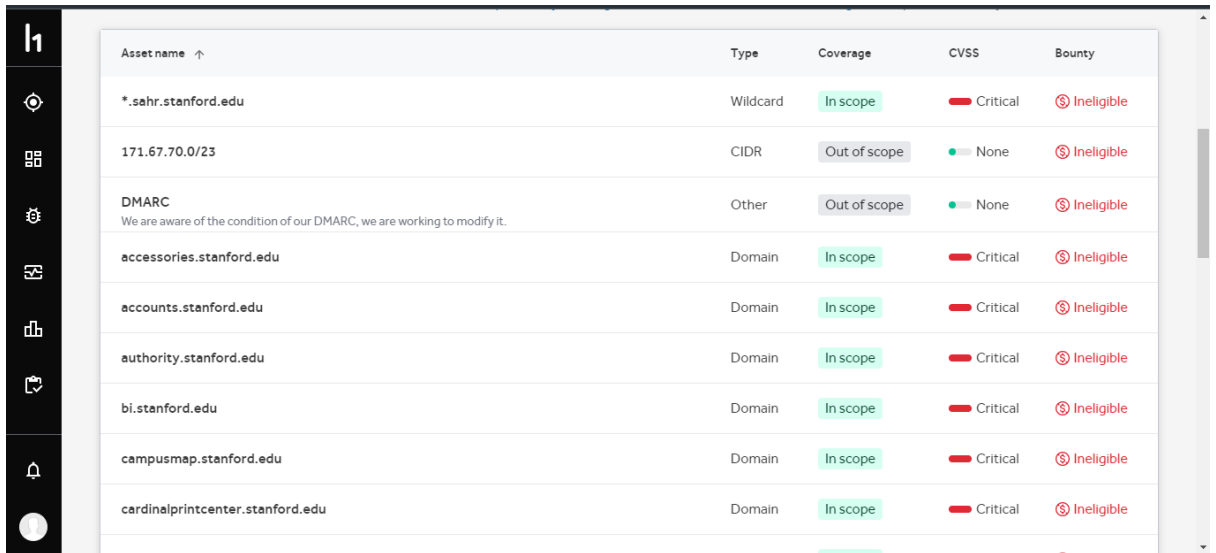
- **Vulnerability title:** Out-of-date Version (jQuery)
- **Owsap Vulnerability-** Using Components with Known Vulnerabilities
- **Vulnerability description:** Out-of-date Version (jQuery)

The use of an older or unpatched version of the jQuery library in a web application is referred to as the "Out-of-date Version (jQuery)" vulnerability. Using an outdated version of jQuery exposes the web application to potential security risks as new vulnerabilities and weaknesses may be discovered in older versions. These flaws can be used by attackers to run arbitrary code, insert malicious scripts, carry out unauthorized operations, or get unauthorized access to confidential data.

- **Affected components:** <http://stanford.edu/>



The following components are in scope.



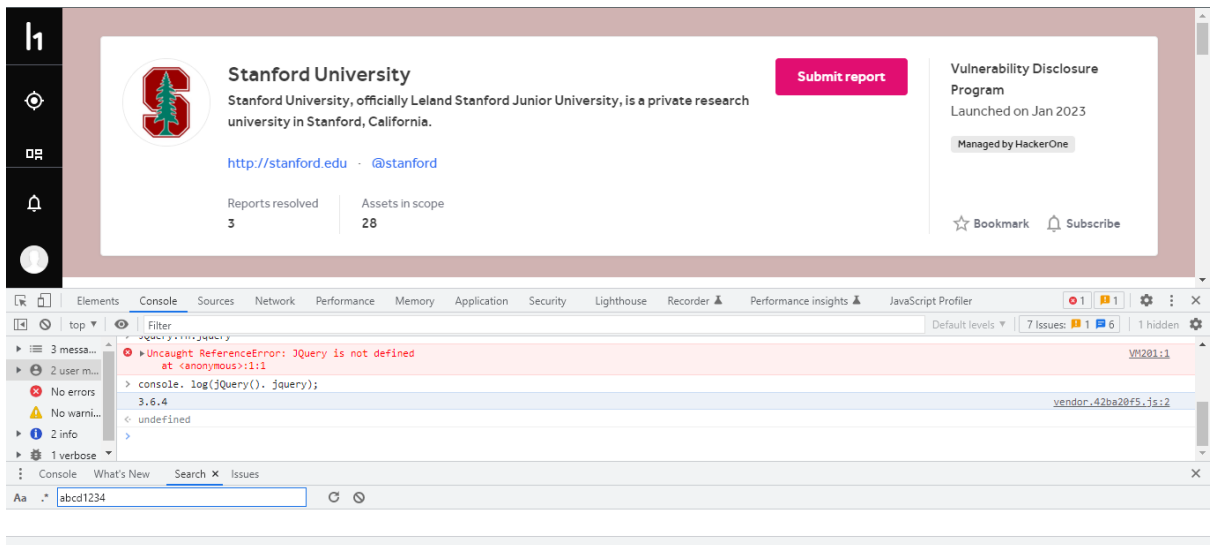
Asset name ↑	Type	Coverage	CVSS	Bounty
*.sahr.stanford.edu	Wildcard	In scope	Critical	Ineligible
171.67.70.0/23	CIDR	Out of scope	None	Ineligible
DMARC We are aware of the condition of our DMARC, we are working to modify it.	Other	Out of scope	None	Ineligible
accessories.stanford.edu	Domain	In scope	Critical	Ineligible
accounts.stanford.edu	Domain	In scope	Critical	Ineligible
authority.stanford.edu	Domain	In scope	Critical	Ineligible
bi.stanford.edu	Domain	In scope	Critical	Ineligible
campusmap.stanford.edu	Domain	In scope	Critical	Ineligible
cardinalprintcenter.stanford.edu	Domain	In scope	Critical	Ineligible

- Impact assessment :** A malicious actor may take advantage of vulnerabilities in outdated versions, which might allow unauthorized access, data leaks, or other security breaches. Using earlier versions of jQuery might also cause compatibility problems. There may be compatibility issues between current web technologies, frameworks, and browsers, which can lead to functionality issues, inconsistent behavior, or even total failures of some capabilities. Another consequence of using an outdated version is the absence of bug patches and updates. Unresolved bugs and issues can continue to exist without the ability to get the required updates and fixes, potentially leading to errors and unexpected behavior in your code. Additionally, locating community support for earlier versions might get harder and harder, making it more difficult to debug problems or ask for help. It can be challenging to maintain an out-of-date codebase because deprecated techniques and inconsistencies might appear, making it more difficult to maintain consistency and maintain maintenance efforts. Using an old version of jQuery means business will not benefit from new features and performance enhancements added in later releases. The performance of your website or online application may suffer as a result, decreasing its speed, effectiveness, and usability.

Web Security - IE2062**Year 2 Semester 2 - 2023**

- **Steps to reproduce :**

Firstly, I checked the jQuery version of this website by using **console.log(jQuery().jquery);** this code in console.



Then I checked on official website of jQuery to find out the latest version of JQuery.
<https://jquery.com/>

According to the site the latest version is 3.7.0

Web Security - IE2062

Year 2 Semester 2 - 2023

- **Proof of concept (if applicable) :**

Here are the IP addresses



```
File Actions Edit View Help
(kaali@kali)-[~]
$ nslookup stanford.edu
Server:      192.168.8.1
Address:     192.168.8.1#53

Non-authoritative answer:
Name:   stanford.edu
Address: 171.67.215.200
Name:   stanford.edu
Address: 2607:f6d0:0:925a::ab43:d7c8

(kaali@kali)-[~]
$
```

Here are the sub domains from Knockpy

The screenshot shows a Kali Linux terminal window titled "kaali@kali:". The user has run the command `knockpy stanford.edu`. The output displays the ASCII art logo for Knockpy v6.1.0. Below the logo, it shows the local IP as 10757 and the remote IP as 3600. The wordlist used is 14357, targeting stanford.edu with IP 171.67.215.200. At the bottom, there is a timestamp of 11:01:07 and a table of scan results.

Ip address	Code	Subdomain	Server	Real hostname
54.189.219.25	200	125.stanford.edu	Apache	ucomm-prod2.sta
nford.edu				
171.67.46.133	200	365.stanford.edu		pgnet-lb-1.stan
ford.edu				
171.64.64.64	200	3dscenegraph.stanford.edu	Apache/2.4.6 (CentOS)	CS.stanford.edu
54.81.116.232	200	1onieval.stanford.edu	nginx	stanford.dns.bl
.ink				
171.64.64.64	200	3ddl.stanford.edu	Apache/2.4.6 (CentOS)	CS.stanford.edu
171.64.64.64	200	3d-r2n2.stanford.edu	Apache/2.4.6 (CentOS)	CS.stanford.edu
159.89.149.97	200	3dqLab.stanford.edu	Apache	stanford.reclai
mhosting.com				
171.64.64.64	200	3dv.stanford.edu	Apache/2.4.6 (CentOS)	CS.stanford.edu
198.185.159.145	200	2025.stanford.edu	Squarespace	ext-cust.square

Web Security - IE2062

Year 2 Semester 2 - 2023

File	Actions	Edit	View	Help
171.67.96.212				biobank-hipc.stanford.edu
171.64.7.105				baby.stanford.edu
159.89.149.97	200			biosciadmin.stanford.edu
mhosting.com				Apache
171.65.104.14	200			biosciareers.stanford.edu
stanford.edu				Apache/2.4.46 () Communique/4.3.3
171.65.104.14	200			bioethics.stanford.edu
stanford.edu				Apache/2.4.46 () Communique/4.3.3
171.67.215.200	404			block.stanford.edu
.edu				Apache
171.67.215.200	200			blockchain.stanford.edu
.edu				Apache
34.215.171.12	200			blockines.stanford.edu
live.enterprise-g1.acquia-sites.com				nginx
171.67.215.200	200			blocklab.stanford.edu
.edu				Apache
171.67.37.166	200			biuat4.stanford.edu
				Apache
171.67.37.180	200			biuat1.stanford.edu
				Apache
34.215.171.12	200			blaydes.people.stanford.edu
				nginx
171.65.104.73	200			biosci-irt-dev.stanford.edu
nford.edu				Apache
74.217.243.22	200			bioapps.stanford.edu
				Apache
171.67.215.200	404			bmecs.stanford.edu
.edu				Apache
44.205.208.103	200			bmir.stanford.edu
lthcare.org				Apache/2.4.46 () Communique/4.3.3
171.65.104.14	200			biosecurity.stanford.edu
stanford.edu				Apache/2.4.46 () Communique/4.3.3

File	Actions	Edit	View	Help
171.67.37.166	200			biuat4.stanford.edu
				Apache
171.67.37.180	200			biuat1.stanford.edu
				Apache
34.215.171.12	200			blaydes.people.stanford.edu
				nginx
171.65.104.73	200			biosci-irt-dev.stanford.edu
nford.edu				Apache
74.217.243.22	200			bioapps.stanford.edu
				Apache
171.67.215.200	404			bmecs.stanford.edu
.edu				Apache
44.205.208.103	200			bmir.stanford.edu
lthcare.org				Apache/2.4.46 () Communique/4.3.3
171.65.104.14	200			biosecurity.stanford.edu
stanford.edu				Apache/2.4.46 () Communique/4.3.3
34.215.171.12	200			blume.stanford.edu
live.enterprise-g1.acquia-sites.com				nginx
171.64.13.20	200			bmirit.stanford.edu
stanford.edu				Apache
44.205.208.103	200			bmt.stanford.edu
lthcare.org				Apache/2.4.46 () Communique/4.3.3
54.81.116.232	200			blink1.stanford.edu
.ink				nginx
171.65.104.14	200			bipolar.stanford.edu
stanford.edu				Apache/2.4.46 () Communique/4.3.3
171.65.104.14	200			bipolarresearch.stanford.edu
stanford.edu				Apache/2.4.46 () Communique/4.3.3
34.210.181.5	200			blending.stanford.edu
g-1150872488.us-west-2.elb.amazonaws.com				Apache
159.89.149.97	200			biosciences.stanford.edu
mhosting.com				Apache
171.64.160.72				birmingham.stanford.edu

```

File Actions Edit View Help
.ink
171.67.37.3 book.stanford.edu swp.stanford.ed
u
171.65.104.14 bogylab.stanford.edu med1.irt-dr.med
.stanford.edu bomgar-techbar.stanford.edu bomgar64.stanfo
rd.edu boettigerlab.stanford.edu stanford.reclai
159.89.149.97 mhosting.com
172.27.213.209 boron.stanford.edu
34.215.171.12 bosp.stanford.edu cardinalsites01
live.enterprise-g1.acquia-sites.com med1.irt-dr.med
171.65.104.14 boothroydlab.stanford.edu stanford.reclai
159.89.149.97 bookhaven.stanford.edu cardinalsites01
mhosting.com bondholder-information.stanford.edu swp.stanford.ed
34.215.171.12 books.stanford.edu sul-bookdata-pr
live.enterprise-g1.acquia-sites.com med1.irt-dr.med
171.67.37.3 bookdata.stanford.edu med1.irt-dr.med
u
171.67.21.64 bmrgroup.stanford.edu med1.irt-dr.med
od.stanford.edu bmi.stanford.edu
171.65.104.14 boussard-lab.stanford.edu
.stanford.edu bospapp.stanford.edu
171.65.104.14 boole.stanford.edu
74.217.243.25
171.64.78.65
[ctrl+c] | 12.6% | cache3.stanford.edu

```

3. Out-of-date Version (jQuery)

MEDIUM  1

Netsparker identified the target web site is using jQuery and detected that it is out of date.

Impact

Since this is an old version of the software, it may be vulnerable to attacks.

jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

jQuery before 3.0.0 is vulnerable to Cross-site Scripting (XSS) attacks when a cross-domain Ajax request is performed without the dataType option, causing text/javascript responses to be executed.

Affected Versions

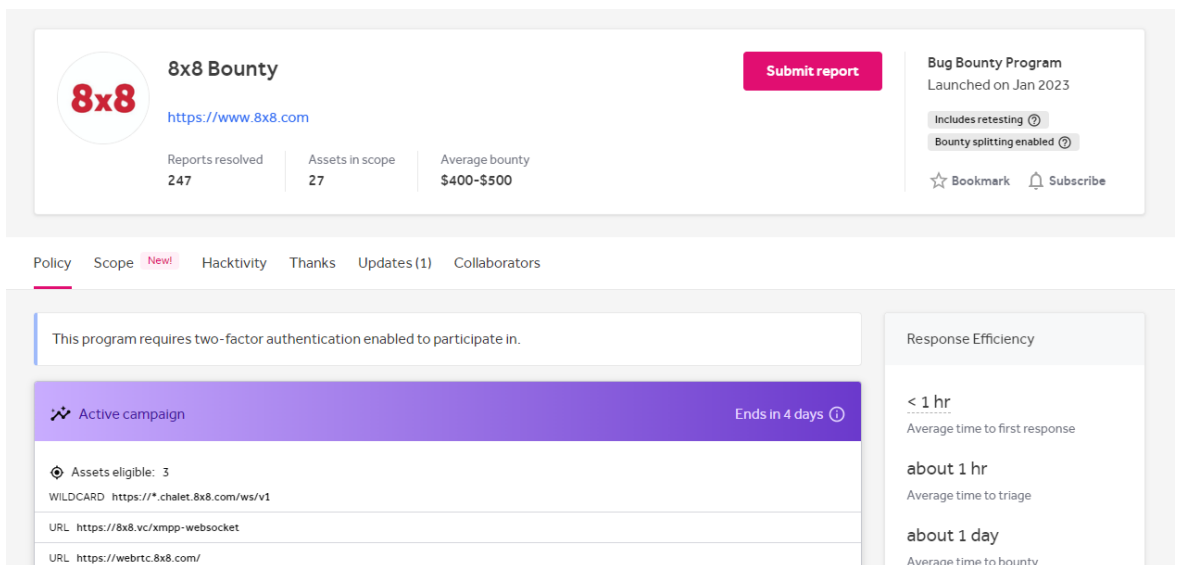
1.8.0 to 2.2.4

- **Proposed mitigation or fix :**

1. **Update JQuery-** The first and most effective method is to upgrade the jQuery library to the latest version. For the latest and most recent version, go to the official JQuery website (<https://jquery.com/>). This will fix the bugs and security patch
2. **Test Compatibility-** Test your code base with the latest jQuery version before making the switch to make sure that there are no compatibility problems.
3. **Replace Deprecated Functions-** Check for any deprecated functions or methods in the release notes or documentation for the current version of jQuery. To keep compatibility and security, replace it with the suggested substitutes.
4. **Use a Content Delivery Network (CDN)-** Instead of hosting jQuery on server, consider using a CDN-hosted version. Business may use CDNs to ensure that they are utilizing the most recent version of jQuery without having to manually update it by taking advantage of its caching, quicker delivery, and automatic updates features.
5. **Regularly Monitor Updates-** Develop informed with jQuery updates and security warnings. Get updates on security fixes, new versions, and best practises by subscribing to official jQuery channels or newsletters. By staying current with updates, businesses can quickly fix any vulnerabilities that could develop in the future.
6. **Implement Content Security Policies (CSP)-** Cross-site scripting assaults are further shielded by content security policies. Set up a Content-Security-Policy header on the website's server to prevent scripts, including inline scripts,
7. **Perform Security Audits-** Conduct routine security audits on the codebase of online application to find and fix any possible flaws, including jQuery-related ones. To help detect and reduce any security concerns, consider using security scanning tools or enlisting the assistance of security experts.

Report 03

- **Vulnerability title** - HTTP Strict Transport Security (HSTS) Errors and Warnings
- **Owsap vulnerability**- Security Misconfiguration
- **Vulnerability description** - HTTP Strict Transport Security (HSTS) Errors and Warnings refer to issues encountered during the implementation of HSTS on a website. HSTS is used in order to ensure secure HTTPS connections between web browsers and websites, Incorrect header settings, expired certificates, or problems with other security features can all result in errors or warnings in the HSTS setup. To provide a secure communication connection and safeguard sensitive user data against downgrade attacks, these problems must be fixed. Maintaining the integrity and efficacy of HSTS in strengthening website security requires close attention to and rapid response to HSTS failures and alerts.
- **Affected components** – <https://www.8x8.com/>



The screenshot displays the 8x8 Bounty program interface. At the top, the 8x8 logo is shown next to the text "8x8 Bounty" and the URL "https://www.8x8.com". A "Submit report" button is visible. Below this, statistics are listed: "Reports resolved 247", "Assets in scope 27", and "Average bounty \$400-\$500". To the right, it states "Bug Bounty Program Launched on Jan 2023" and includes features like "Includes retesting" and "Bounty splitting enabled". A navigation bar at the bottom includes links for "Policy", "Scope", "Hacktivity", "Thanks", "Updates (1)", and "Collaborators". The main content area shows a message: "This program requires two-factor authentication enabled to participate in." Below this, an "Active campaign" section lists eligible assets: "WILDCARD https://*.chalet.8x8.com/ws/v1", "URL https://8x8.vc/xmpp-websocket", and "URL https://webtrc.8x8.com/". On the right, a "Response Efficiency" sidebar shows metrics: "< 1 hr" for average time to first response, "about 1 hr" for average time to triage, and "about 1 day" for average time to bounty.

Web Security - IE2062
Year 2 Semester 2 - 2023

Here is the scope

Asset name ↑	Type	Coverage	CVSS	Bounty
*.8x8.vc Professional Meetings and Jitsi as a Service. At this time 8x8 does not provide credentials and researchers are responsible for any fees occurred if signing up for the service. Amazon Web Services C++ Java JavaScript Kotlin Objective-C Oracle Cloud React	Wildcard	In scope	Critical	Eligible
*.8x8staging.com	Wildcard	In scope	Critical	Eligible
*.chalet.8x8.com	Wildcard	In scope	Critical	Eligible
*.contactnow.8x8.com English JavaScript PHP	Wildcard	Out of scope	None	Ineligible
*.jit.si Amazon Web Services C++ Java JavaScript Kotlin Objective-C Oracle Cloud React	Wildcard	In scope	Critical	Eligible
*.jitsi.net Amazon Web Services Oracle Cloud	Wildcard	In scope	Critical	Eligible
*.jitsi.org	Wildcard	Out of scope	None	Ineligible

- Impact assessment** - The effects of HTTP Strict Transport Security (HSTS) Errors and Warnings vary based on the issues detected. This can reduce a website's security and attack ability. The connection between a user's web browser and a website can be interfered with when HSTS is not configured properly or is switched off, which can put sensitive information at risk. Additionally damaging to the website's image and leading visitors to lose faith in its security are these faults and warnings. They could even result in breaches of laws and standards set by the industry in specific circumstances. Additionally, HSTS mistakes and alerts can ruin the user experience by displaying alerts or blocking access to the website.

Web Security - IE2062**Year 2 Semester 2 - 2023**

- **Steps to reproduce –**

1. Configure a web server: Install and set up a web server (such as Apache or Nginx) on a local or test PC.
2. Create or get an SSL/TLS certificate: Make that the website has a working SSL/TLS certificate. This can be acquired by self-signed certificates for testing or from a reliable certificate authority.
3. Install the SSL/TLS certificate on the web server and set the server up to allow HTTPS-secured connections to enable HTTPS.
4. Configure the HSTS header by including it in the HTTP response headers or web server settings. The "Strict-Transport-Security" directive should be included in the header, indicating the HSTS policy and the desired length, such as "max-age=31536000" for a one-year period.
5. Examine the HSTS behavior: Use a web browser that supports HSTS to access the website. For subsequent visits to the website within the defined time frame, the browser needs to enforce a secure HTTPS connection automatically recognizing the HSTS header.
6. Check the HSTS system's operation by making sure the web browser mandates HTTPS connections and switches all HTTP requests to HTTPS. Check the HTTP response headers with tools or browser add-ons to see if the HSTS header is present.

- **Proof of concept (if applicable)**

Here is possible ip addresses

Web Security - IE2062**Year 2 Semester 2 - 2023**

```
File Actions Edit View Help
(kaali@kali)-[~]
$ nslookup 8x8.com
Server:      192.168.8.1
Address:     192.168.8.1#53

Non-authoritative answer:
Name:   8x8.com
Address: 54.69.33.46

(kaali@kali)-[~]
$
```

Here are the open ports I scanned using nmap

```
(kaali@kali)-[~]
$ nslookup 8x8.com
Server:      192.168.8.1
Address:     192.168.8.1#53

Non-authoritative answer:
Name:   8x8.com
Address: 54.69.33.46

(kaali@kali)-[~]
$ nm
nm: 'a.out': No such file

(kaali@kali)-[~]
$ sudo nmap 54.69.33.46
[sudo] password for kaali:
Starting Nmap 7.92 ( https://nmap.org ) at 2023-05-28 06:25 CDT
Nmap scan report for ec2-54-69-33-46.us-west-2.compute.amazonaws.com (54.69.33.46)
Host is up (0.029s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 14.11 seconds

(kaali@kali)-[~]
$
```

Here are the sub domains

Web Security - IE2062

Year 2 Semester 2 - 2023

```

kaali@kali: ~
└─$ knockpy 8x8.com

v6.1.0

local: 10757 | remote: 1729
Wordlist: 12486 | Target: 8x8.com | Ip: 54.69.33.46
11:28:44

Ip address      Code Subdomain      Server      Real hostname
-----
54.69.33.46     0 8x8.com           103-239-164-81.8x8.com  dns-default.8x8.com
54.69.33.46     103-239-164-81.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-102.8x8.com  dns-default.8x8.com
54.69.33.46     103-239-164-166.8x8.com  dns-default.8x8.com
54.69.33.46     1-ghcpi.238-85.8x8.com  dns-default.8x8.com
54.69.33.46     10.8x8.com           dns-default.8x8.com
54.69.33.46     01.8x8.com           dns-default.8x8.com
54.69.33.46     103-239-164-31.8x8.com  dns-default.8x8.com
54.69.33.46     1000.8x8.com          dns-default.8x8.com
54.69.33.46     103-252-162-101.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-100.8x8.com  dns-default.8x8.com
54.69.33.46     103-239-164-194.8x8.com  dns-default.8x8.com
54.69.33.46     103-239-164-152.8x8.com  dns-default.8x8.com
54.69.33.46     1-p.238-126.8x8.com     dns-default.8x8.com
54.69.33.46     09.8x8.com           dns-default.8x8.com

```

```

kaali@kali: ~
54.69.33.46     103-252-162-100.8x8.com  dns-default.8x8.com
54.69.33.46     103-239-164-194.8x8.com  dns-default.8x8.com
54.69.33.46     103-239-164-152.8x8.com  dns-default.8x8.com
54.69.33.46     1-p.238-126.8x8.com     dns-default.8x8.com
54.69.33.46     09.8x8.com           dns-default.8x8.com
54.69.33.46     101.8x8.com           dns-default.8x8.com
54.69.33.46     102-252-162-156.8x8.com  dns-default.8x8.com
54.69.33.46     103-239-164-178.8x8.com  dns-default.8x8.com
54.69.33.46     103-239-164-5.8x8.com   dns-default.8x8.com
54.69.33.46     02.8x8.com           dns-default.8x8.com
54.69.33.46     103-252-162-0.8x8.com   dns-default.8x8.com
54.69.33.46     03.8x8.com           dns-default.8x8.com
54.69.33.46     103-239-164-80.8x8.com  dns-default.8x8.com
54.69.33.46     10-8-5-248-39.8x8.com   dns-default.8x8.com
54.69.33.46     103-252-162-1.8x8.com   dns-default.8x8.com
54.69.33.46     000.8x8.com           dns-default.8x8.com
54.69.33.46     1-236-35-1.8x8.com     dns-default.8x8.com
54.69.33.46     100.8x8.com           dns-default.8x8.com
54.69.33.46     103-239-164-116.8x8.com  dns-default.8x8.com
54.69.33.46     1.8x8.com             dns-default.8x8.com
54.69.33.46     103-252-162-105.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-108.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-117.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-109.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-11.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-116.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-115.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-114.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-111.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-113.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-12.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-112.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-118.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-110.8x8.com  dns-default.8x8.com
54.69.33.46     103-252-162-121.8x8.com  dns-default.8x8.com

```



```

kali@kali: ~
54.69.33.46 103-252-162-11.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-116.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-115.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-114.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-111.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-113.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-12.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-112.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-118.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-110.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-121.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-122.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-125.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-127.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-122.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-119.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-13.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-128.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-106.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-107.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-131.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-120.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-103.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-126.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-133.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-138.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-139.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-137.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-135.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-134.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-136.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-14.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-140.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-143.8x8.com dns-default.8x8.com
54.69.33.46 103-252-162-147.8x8.com dns-default.8x8.com

```

1. HTTP Strict Transport Security (HSTS) Errors and Warnings

MEDIUM 1

Netsparker detected errors during parsing of Strict-Transport-Security header.

Impact

The HSTS Warning and Error may allow attackers to bypass HSTS, effectively allowing them to read and modify your communication with the website.

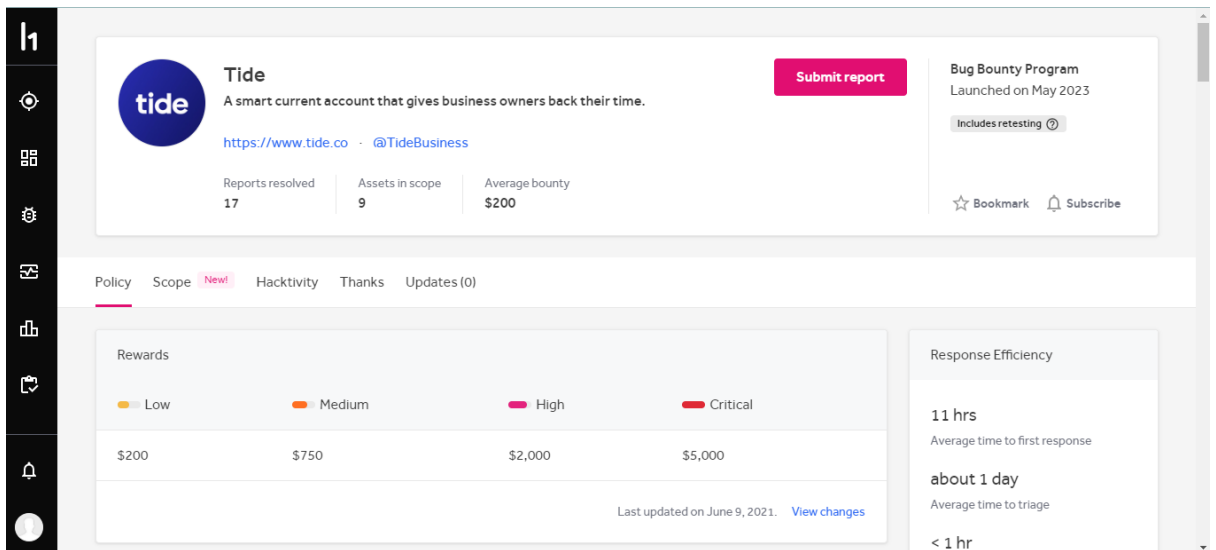
Web Security - IE2062**Year 2 Semester 2 - 2023**

- **Proposed mitigation or fix**

1. **Correct HSTS configuration:** Verify that the web server's HSTS header is set up properly. To indicate the timeframe during which the HSTS policy shall be in effect, set the appropriate "max-age" directive.
2. **Enable HTTPS:** Put HTTPS into practice on your website to guarantee that all communication is secured. Get a legitimate SSL/TLS certificate from a reputable certificate authority, then install it.
3. **Configure your web server** so that all HTTP queries are sent to HTTPS. This stops visitors from using unsafe HTTP connections to access the website.
4. **Identify certificate problems:** Keep track of your SSL/TLS certificate's status often. Make sure it does not pass away or lose its validity. Resolve any certificate-related issues or warnings and renew certificates on schedule.
5. **Verify that the SSL/TLS certificate shown by your website is trusted by the main web browsers and operating systems.** This is known as validating certificate trust. This guarantees that visitors will not encounter security issues or warnings.
6. **Implement appropriate HTTP response headers:** To improve the overall security posture of your website, in addition to HSTS, specify additional pertinent HTTP response headers, such as Content Security Policy (CSP) and X-Frame-Options.
7. **The HSTS implementation on your website should be regularly tested using a variety of browsers and tools to make sure it is correctly enforcing secure HTTPS connections.**
8. **Keep an eye out for and fix HSTS failures and warnings:** Observe any HSTS-related warnings or problems that are given by browsers or security programs.
9. **Keep updated on best practises**

Report 04

- **Vulnerability title** - Out-of-date Version (WordPress)
- **Owsap Vulnerability** - Using components with known vulnerabilities
- **Vulnerability description** - An out-of-date version of WordPress refers to an older iteration of the popular CMS used for creating and managing websites. WordPress has a user-friendly interface and a wide range of customization possibilities, but to improve functionality, security, and speed, it must be updated frequently. The newest features, bug fixes, and security updates are lost when users do not update their WordPress installations, leaving them with an outdated version. This poses risks such as limited functionality and increased vulnerability to security threats. This poses risks such as limited functionality and increased vulnerability to security threats.
- **Affected components** – <https://www.tide.co/>



The screenshot shows the Tide Bug Bounty Program page. It features a sidebar with navigation icons, a main content area with a 'Submit report' button, and a 'Bug Bounty Program' section. The 'Bug Bounty Program' section includes a table for 'Rewards' and a 'Response Efficiency' section.

Rewards			
Low	Medium	High	Critical
\$200	\$750	\$2,000	\$5,000

Response Efficiency

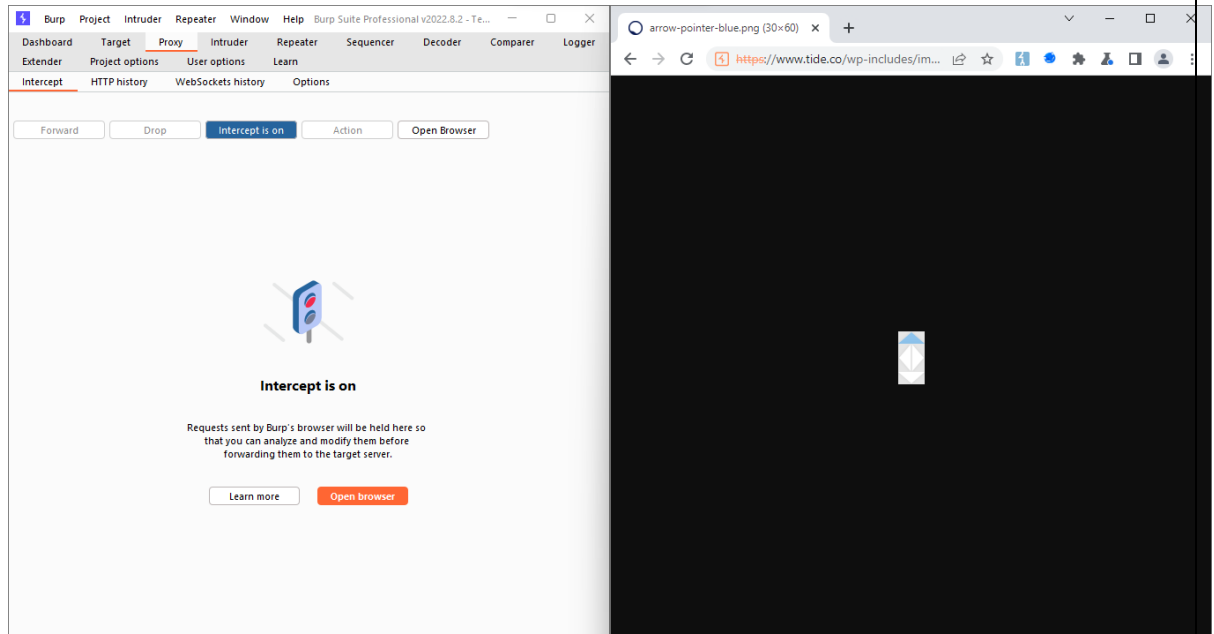
- 11 hrs
Average time to first response
- about 1 day
Average time to triage
- < 1 hr

Here are the domains in scope

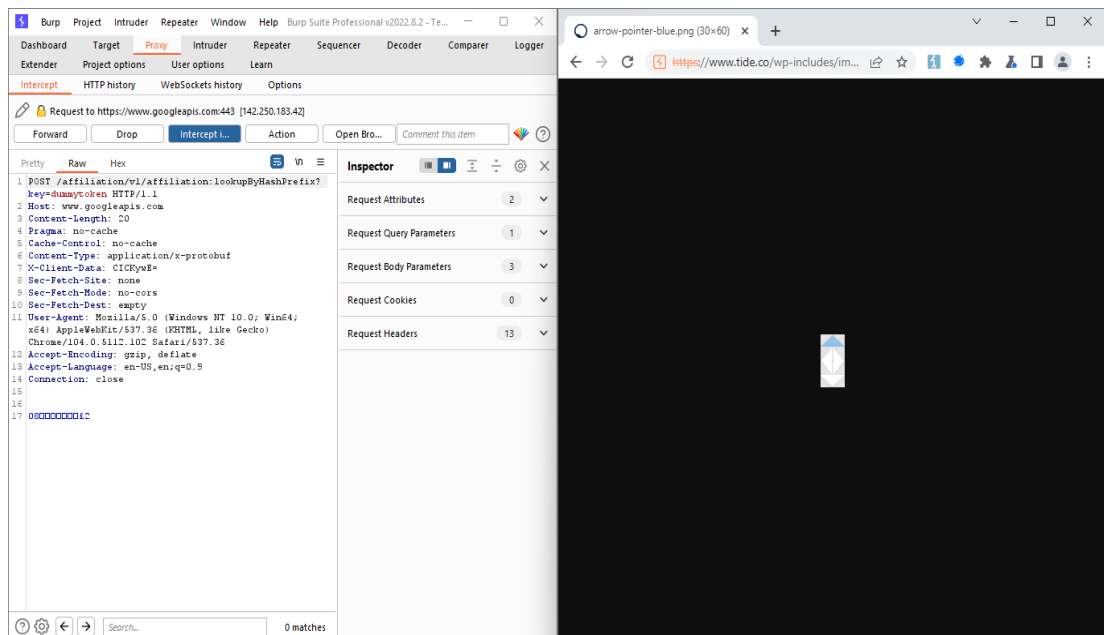
Web Security - IE2062
Year 2 Semester 2 - 2023

api.tideplatform.in	Domain	In scope	Critical	Eligible
Amazon DynamoDB AmazonRDS Amazon Web Services Flask Java Python Spring Boot				
app.tide.co	Domain	In scope	Critical	Eligible
co.tide	iOS: App Store	In scope	Critical	Eligible
Dart				
co.tide.tideplatform.in	Android: Play Store	In scope	Critical	Eligible
Dart				
com.tideplatform.banking	Android: Play Store	In scope	Critical	Eligible
Dart				
community.tide.co	Domain	Out of scope	None	Ineligible
domains.tide.co	Domain	Out of scope	None	Ineligible
http://*-staging.tide.co	Wildcard	Out of scope	None	Ineligible
http://*-win.tide.co	Wildcard	Out of scope	None	Ineligible

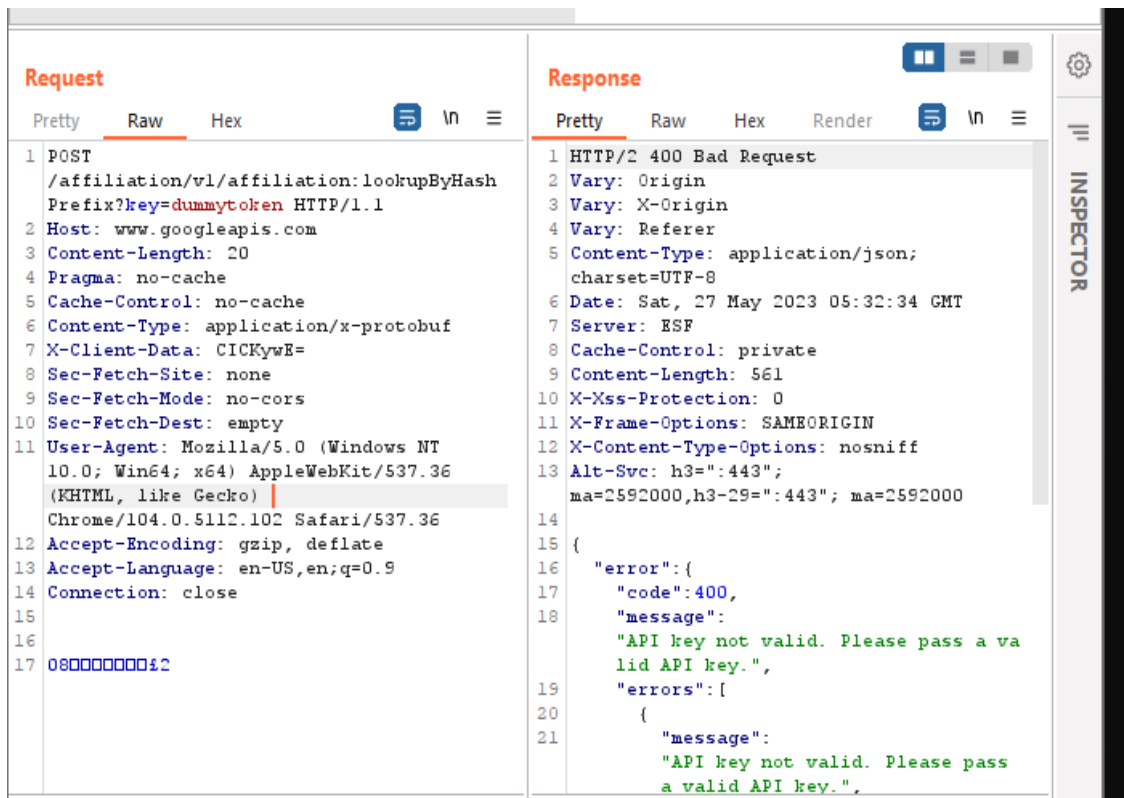
- Impact assessment** –The website's performance could be impacted by using an outdated version of WordPress. The growing vulnerability to security breaches is one of the main concerns. Older versions do not have the latest and most recent security updates, therefore leaving the website open to malware and hacker attack. Unauthorized access, data breaches, and possible harm to the image of website can all arise from this. Furthermore, utilizing an out-of-date version might cause problems with plugins, themes, and web standards. The website could crash, features might not operate as intended, and the user experience could be harmed. As quicker loading times are frequently included into later versions, performance and speed might also suffer. In the end least, outdated versions could not receive enough assistance from the WordPress community, making it difficult to fix problems and putting business at a disadvantage.
- Steps to reproduce –**
 1. Open Burp Suite and configure the browser to use Burp as a proxy. This will allow Burp to intercept and analyze the website's traffic.
 2. Launch your web browser and navigate to the website you want to check



3. Burp Suite will intercept the requests and responses of the website.
4. In Burp Suite, go to the "Proxy" tab and select the "Intercept" sub-tab. Ensure that interception is turned on. Refresh the website in browser, and Burp Suite will capture the request.
5. In Burp Suite, locate the captured request related to the main page or homepage of the website.



6. Right-click on the request and select "Send to Repeater" from the context menu.
7. In the "Repeater" tab of Burp Suite, captured request . This allows you to modify and resend the request.
8. Look for the "User-Agent" header in the request details. This header usually contains information about the browser and the WordPress version.



Request		Response	
Pretty	Raw	Pretty	Raw
1 POST		1 HTTP/2 400 Bad Request	
2 /affiliation/v1/affiliation:lookupByHash		2 Vary: Origin	
3 Prefix?key=dummytoken HTTP/1.1		3 Vary: X-Origin	
4 Host: www.googleapis.com		4 Vary: Referer	
5 Content-Length: 20		5 Content-Type: application/json;	
6 Pragma: no-cache		6 charset=UTF-8	
7 Cache-Control: no-cache		7 Date: Sat, 27 May 2023 05:32:34 GMT	
8 Content-Type: application/x-protobuf		8 Server: ESF	
9 X-Client-Data: CICKyWE=		9 Cache-Control: private	
10 Sec-Fetch-Site: none		10 Content-Length: 561	
11 Sec-Fetch-Mode: no-cors		11 X-Xss-Protection: 0	
12 Sec-Fetch-Dest: empty		12 X-Frame-Options: SAMEORIGIN	
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/104.0.5112.102 Safari/537.36		13 X-Content-Type-Options: nosniff	
14 Accept-Encoding: gzip, deflate		14 Alt-Svc: h3=":443"; ma=2592000,h3-29=":443"; ma=2592000	
15 Accept-Language: en-US,en;q=0.9		15 {	
16 Connection: close		16 "error":{	
17 0800000000f2		17 "code":400,	
		18 "message":	
		19 "API key not valid. Please pass a valid API key.",	
		20 "errors":[	
		21 {	
		22 "message":	
		23 "API key not valid. Please pass a valid API key.",	

9. Check if the User-Agent header mentions "WordPress" and look for any version numbers mentioned.
10. If you find a version number, compare it to the latest WordPress version available on the WordPress website (wordpress.org) to determine if it is out of date.

Web Security - IE2062

Year 2 Semester 2 - 2023

- **Proof of concept (if applicable)**

Nslookup

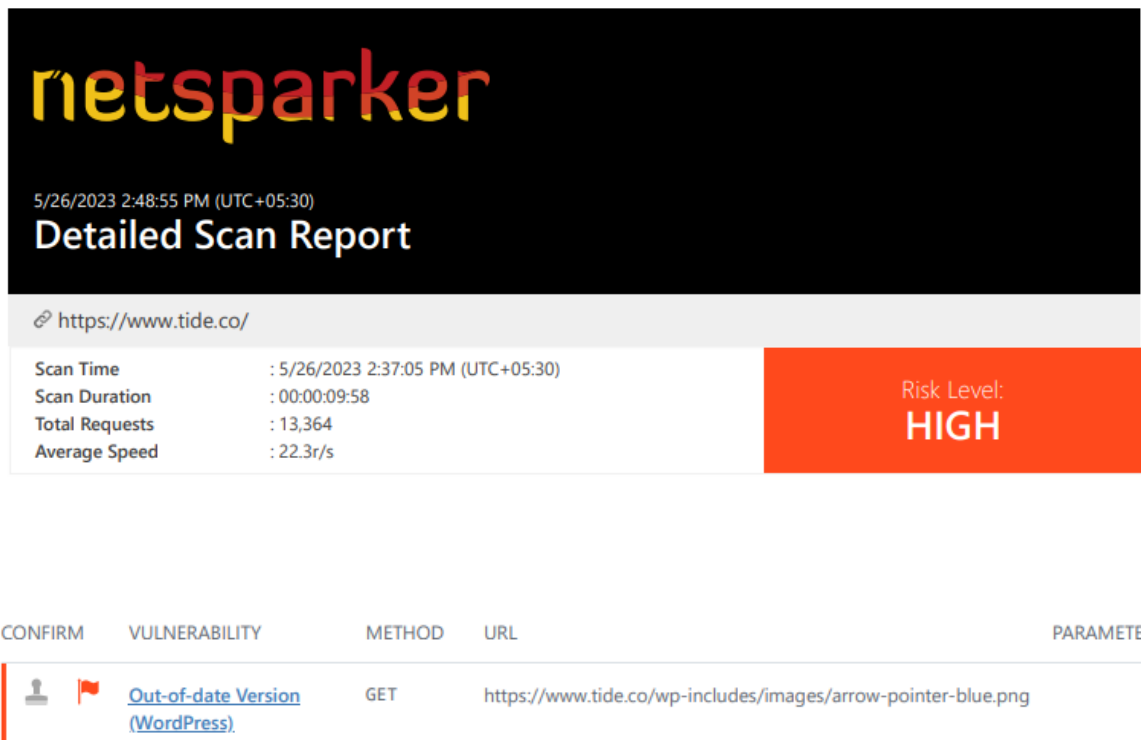
```
kaali@kali: ~  
$ nslookup tide.com  
Server:      192.168.8.1  
Address:     192.168.8.1#53  
  
Non-authoritative answer:  
Name:   tide.com  
Address: 152.199.39.108  
  
kaali@kali: ~  
$
```

KnockPy

```
kaali@kali: ~  
$ nslookup tide.com  
Server:      192.168.8.1#53  
Address:     152.199.39.108  
  
Non-authoritative answer:  
Name:   tide.com  
Address: 152.199.39.108  
  
kaali@kali: ~  
$ knockpy tide.com  
  
v6.1.0  
KnockPy  
Wordlist: 10801 | Target: tide.com | Ip: 152.199.39.108  
local: 10757 | remote: 44  
11:33:04  


| Ip address    | Code | Subdomain                  | Server      | Real hostname           |
|---------------|------|----------------------------|-------------|-------------------------|
| 35.186.229.64 | 400  | analytics.tide.com         | istio-envoy |                         |
| 35.186.229.64 | 404  | analytics-preview.tide.com | istio-envoy |                         |
| 20.72.89.79   | 200  | api.tide.com               |             | az-ag-cs-na-v2-external |

  
-paas-prod-04-pip.eastus2.cloudapp.azure.com  
[ctrl+c] | 10.5% | bruce.tide.com
```



netsparker

5/26/2023 2:48:55 PM (UTC+05:30)
Detailed Scan Report

🔗 <https://www.tide.co/>

Scan Time	: 5/26/2023 2:37:05 PM (UTC+05:30)	Risk Level: HIGH
Scan Duration	: 00:00:09:58	
Total Requests	: 13,364	
Average Speed	: 22.3r/s	

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER
	 Out-of-date Version (WordPress)	GET	https://www.tide.co/wp-includes/images/arrow-pointer-blue.png	

- **Proposed mitigation or fix-**

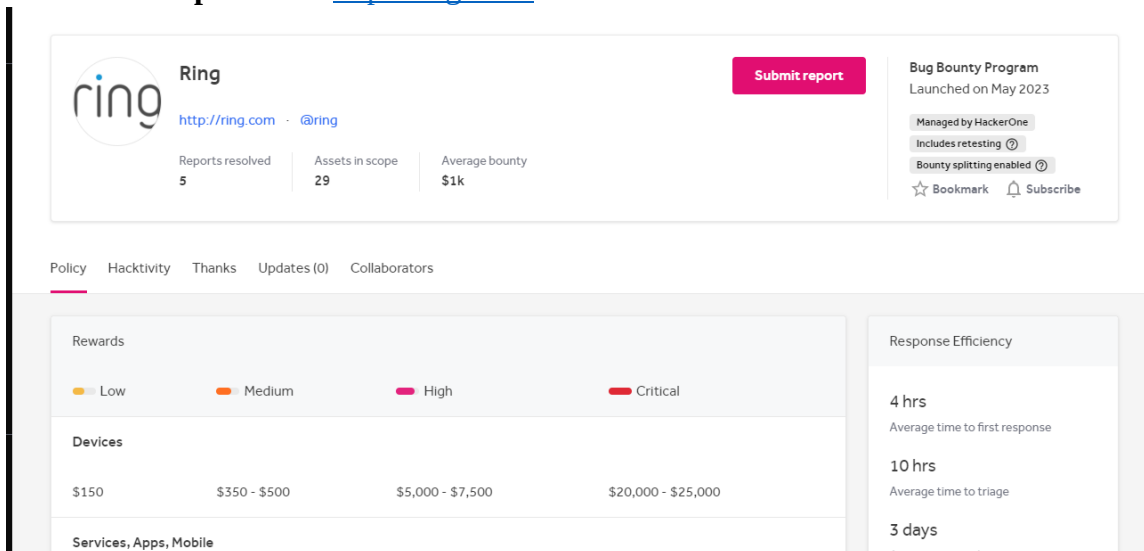
1. **Update WordPress:** Updating the installation of WordPress to the most recent version is the most important step. The new update will obtain the most recent security updates, bug fixes, and performance improvements thanks to this. WordPress may be updated manually or through the WordPress admin dashboard by downloading the most recent version from the official WordPress website.
2. **Update themes and plugins:** Keep the themes and plugins current in addition to upgrading WordPress. Updates are frequently released by developers to fix compatibility issues and fix security flaws. Regularly check the WordPress dashboard or the websites of the relevant theme or plugin developers for changes.

Web Security - IE2062**Year 2 Semester 2 - 2023**

3. Remove unused themes and plugins: Delete any outdated themes or plugins. Themes and plugins that are not utilised or active might still be a security issue if they aren't updated often.
4. Use a Web Application Firewall (WAF)
5. Strengthen passwords
6. Backup the site frequently

Report 05

- **Vulnerability title** - Cross-site Scripting
- **Owsap Vulnerability**- Cross-Site Scripting (XSS)
- **Vulnerability Description**- This vulnerability allows attackers to inject malicious scripts into trusted websites. It happens when an application delivers user-generated input—such as form fields or URL parameters—into web pages without adequately validating or sanitising the data. As a result, unaware visitors visiting the impacted web page may unintentionally run the injected scripts, which can have a number of negative effects, such as the theft of personal data, session hijacking, or website defacement.
- **Affected components** – <http://ring.com/>



The screenshot shows the Ring Bug Bounty Program page on HackerOne. The page header includes the Ring logo, a 'Submit report' button, and program details: 'Bug Bounty Program Launched on May 2023', 'Managed by HackerOne', 'Includes retesting', and 'Bounty splitting enabled'. It also shows 'Reports resolved: 5', 'Assets in scope: 29', and 'Average bounty: \$1k'. Below the header, there are tabs for 'Policy', 'Hacktivity', 'Thanks', 'Updates (0)', and 'Collaborators'. The main content area is divided into two sections: 'Rewards' and 'Response Efficiency'. The 'Rewards' section shows a table with columns for 'Low', 'Medium', 'High', and 'Critical' severity levels, and rows for 'Devices' and 'Services, Apps, Mobile'. The 'Response Efficiency' section shows a table with columns for '4 hrs', '10 hrs', and '3 days' response times, and rows for 'Average time to first response', 'Average time to triage', and 'Average time to bounty'.

Severity	Low	Medium	High	Critical
Devices	\$150	\$350 - \$500	\$5,000 - \$7,500	\$20,000 - \$25,000
Services, Apps, Mobile				

Response Time	4 hrs	10 hrs	3 days
Average time to first response			
Average time to triage			
Average time to bounty			

Policy

Ring and BlinkForHome Bug Bounty Program Overview

We believe that stronger communities are the key to safer neighborhoods. That's why we're driven to create products that help you protect what matters most at home and empower you to connect with your neighbors from wherever you are. Together, we'll make neighborhoods safer.

The Ring and BlinkForHome Bug Bounty Program is designed to recognize security research on our consumer electronics, associated devices, cloud services and web/mobile applications through bounty rewards. If you believe you have discovered a vulnerability impacting our devices and services, we encourage you to report it to us through this portal. Please review this page for our process, responsible research and disclosure policy, reward guidelines, and detailed scope of this program. We are committed to being responsive and keep you informed of our progress on the investigation.

Ring and BlinkForHome Program Process

In order to be eligible for a bounty reward, you must be the first to report an issue to us for assets outlined in scope. To ensure appropriate reward allocations, please provide a detailed report including - software version of device/application research was performed on, clear description of the issue, proof of concept (wherever applicable), along with detailed steps to reproduce the issue; you can optionally also provide patch/mitigation suggestions. We will acknowledge the receipt of the report, and in case of any additional questions, we will communicate and work with you through the HackerOne portal. Once the validity and severity of the reported issue has been confirmed, we will notify you through the HackerOne portal and allocate rewards based on the severity of the reported issue.

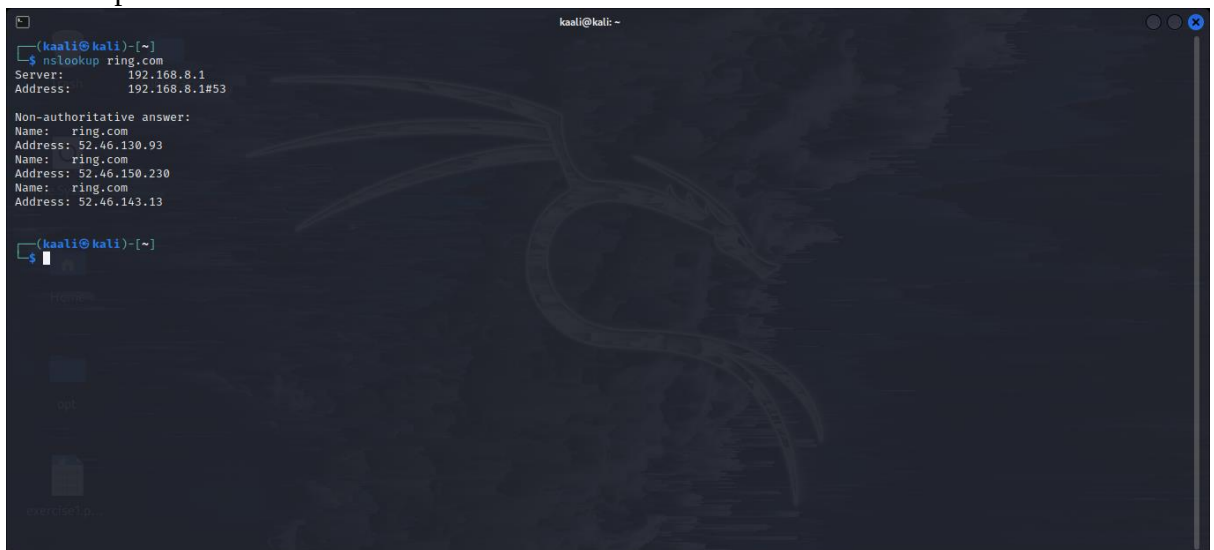
Additionally, to be considered for a reward, you must comply with all parts of this policy, including the following requirements -

- **Impact assessment** – Cross-Site Scripting (XSS) vulnerabilities can have a major effect and severely compromise websites and their users. Attackers can inject harmful scripts into reputable websites using XSS vulnerabilities, and naïve users can subsequently execute such scripts. Numerous negative effects may result from this. For instance, sensitive user data like login passwords, personal information, or financial information may be taken and result in identity theft or financial loss. Additionally, attackers have the ability to take over user sessions, obtaining access to accounts without authorization and carrying out evil deeds on the user's behalf. In addition, XSS flaws provide attackers the ability to deface websites, change content, or send users to malicious websites, harming the reputation and dependability of the afflicted site.
- **Steps to reproduce** –
 1. **Identify Input Fields:** Look for input fields in web applications which haven't been thoroughly verified or sanitized before displaying user-generated content on web sites. On a website, locations like search boxes, comment sections, form fields, and similar places may duplicate user input.
 2. **Create a malicious script** that will be executed when a web page presents an input field that is vulnerable. The script could be JavaScript-based and have the ability to perform a variety of destructive acts, such as stealing cookies or redirecting visitors to malicious websites.

Web Security - IE2062**Year 2 Semester 2 - 2023**

3. Input Malicious Content: Enter the script you developed into the vulnerable input form that was specified. This can be done by filling out a form, writing a comment, or another method depending on the specific circumstances of the vulnerable application.
4. Open the web page where the malicious input is shown after it has been inserted or submitted to watch the script execution. The script should be executed when the victim's browser accesses the website, producing the desired harmful outcome.
5. Check for Successful Exploitation: To ensure that the XSS vulnerability has been effectively exploited, look at the predicted behaviour or effects. Finding out if the script was executed, personal information was accessed, unauthorised actions were made, or other harmful outcomes may be required.

- **Proof of concept (if applicable)**

Nslookup

```
kaali@kali: ~  
$ nslookup ring.com  
Server:      192.168.8.1  
Address:     192.168.8.1#53  
  
Non-authoritative answer:  
Name:   ring.com  
Address: 52.46.130.93  
Name:   ring.com  
Address: 52.46.150.230  
Name:   ring.com  
Address: 52.46.143.13  
  
kaali@kali: ~  
$
```

1. Cross-site Scripting

HIGH 1

Netsparker detected Cross-site Scripting, which allows an attacker to execute a dynamic script (*JavaScript*, *VBScript*) in the context of the application.

This allows several different attack opportunities, mostly hijacking the current session of the user or changing the look of the page by changing the HTML on the fly to steal the user's credentials. This happens because the input entered by a user has been interpreted as HTML/JavaScript/VBScript by the browser. Cross-site scripting targets the users of the application instead of the server. Although this is a limitation, since it allows attackers to hijack other users' sessions, an attacker might attack an administrator to gain full control over the application.

Impact

There are many different attacks that can be leveraged through the use of cross-site scripting, including:

- Hijacking user's active session.
- Mounting phishing attacks.
- Intercepting data and performing man-in-the-middle attacks.

Vulnerabilities

1.1. [https://ring.com/search?q=%27%22%20ns%3dnetsparker\(0x004248\)%20#SVGID_2_](https://ring.com/search?q=%27%22%20ns%3dnetsparker(0x004248)%20#SVGID_2_)

Here is the request and response part.

Request

```
GET /search?q=%27%22%20ns%3dnetsparker(0x004248)%20#SVGID_2_ HTTP/1.1
Host: ring.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Encoding: gzip, deflate
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: rsas=04a2e6c0-51e1-491b-8532-72e5382a9c94; _a_id=693b170d-9639-45de-aea0-a7ce8c51986c; _slvddv=true; _slvcl=en; rs_hwid=dfae251e-0525-4509-8400-218362c0301c; _srsb=883ccb1-25c7-4bb2-b979-44e02722e9b1; _fs_sample_user=true; rs_sis=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpvcXJ9.eyJjc3JmVG9rZW4iOiJlNTI1aSEEdQZmgxY0FrYU0wbHluMS1BIiwiaXhwaXJlciRzIjoxNjg0NTY5ODQyODQ4LCJpcCI6IjEwMS4yLjE4ODUyMzI1c2VyaWdlbnQ1IjNjb3p0bGxhZUuMCAoV2luZG93cyBOVCAXMC4wOyB4NjQpIEFwcGxlV2ViS2l0LzUzNy4zNi1AoS0hUTUwsIGxpZUgR2Vja28pIENocm9tZS83MC4wLjM1MzguNzcgU2FmYXJpLzUzNy4zNi1IsImhhcmR3YXJlSWQ1O1JkZmFIMjUxZS0wNTI1LTQ1MDktODQwMC0yNTgzNjJjMDMwMWM1LCJpYXQ1OjE2ODQ1Njg5NDIsImF1ZCI6Imh0dHBzOi18vcmLuZy5jb201LCJpc3MiOiJ3Saw5nIn0.nui59EsrBLYSLHL-Zw8o9w94w0NmY9SeASB2WJUPa0; _slvs=29e9bdf4-92ae-4e14-8210-69acc366a7d8; campaign=%7B%22data%22%3A%7B%22utm_source%22%3A%22utm_medium%22%3A%22utm_campaign%22%3A%22utm_content%22%3A%22utm_term%22%3A%22referrer%22%3A%22%22%22path%22%3A%22F%22%7D%7D; _cmp_a=%7B%22purposes%22%3A%7B%22a%22%3Atrue%2C%22p%22%3Atrue%2C%22m%22%3Atrue%2C%22t%22%3Atrue%7D%22display_banner%22%3Afalse%2C%22merchant_geo%22%3A%22USUSCA%22%22sale_of_data_region%22%3Afalse%7D; _s=8553a7c1-dfb6-4485-ba48-097265251921; _shopify_s=8553a7c1-dfb6-4485-ba48-097265251921; _shopify_y=38ab468f-09f2-485b-b0f5-dd0036d548d2; _y=38ab468f-09f2-485b-b0f5-dd0036d548d2; privacy-banner=true; privacy-banner-clicked=true; privacy-cookie=%7B%22version%22%3A1%22%22analytics_heap%22%3Afalse%2C%22analytics_optimize%22%3Afalse%2C%22analytics_yext%22%3Afalse%2C%22analytics_fullstory%22%3Afalse%2C%22advertising_amazondisplay%22%3Afalse%2C%22advertising_kenshoo%22%3Afalse%3Bexpr%20268409241%20-%2078732%3Bx%22%22advertising_size%22%3Afalse%2C%22consentUrl%22%3A%22https%3A%2F%2Fring.com%2F%22%22consentDate%22%3A%22Sat%2C%2020%20May%202023%2007%3A37%3A24%20GMT%22%7D; rs_geo=AU; rw_locale=%2Fau%2Fen; rw_mp=AU
Referer: https://ring.com/
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/70.0.3538.77 Safari/537.36
```

Web Security - IE2062**Year 2 Semester 2 - 2023****Response**

Response Time (ms) : 630.2255 Total Bytes Received : 88586 Body Length : 88111 Is Compressed : No

```
HTTP/1.1 200 OK
Server: Server
X-Content-Type-Options: nosniff
X-Powered-By: Express
Connection: keep-alive
X-Request-Id: 44xbygswpa39onxztix0
X-Frame-Options: SAMEORIGIN
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
x-amz-rid: JVG03NPFCV09AP5Q8E2F
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Content-Encoding:
Date: Sat, 20 May 2023 07:50:01 GMT
Vary: Accept-Encoding,Content-Type,Accept-Encoding,User-Agent

<!DOCTYPE html>
<html lang="en" class="no-focus-outline">
<head>
<link href="https://d39xvdj9d5ntm1.cloudfront.net/common/" rel="preconnect" crossorigin>
<link href="https://site-nav.ring.com" rel="preconnect" crossorigin>
<link href="https://static.ring.com" rel="preconnect" crossorigin>
<link href="https://images.ctfassets.net" rel="preconnect" crossorigin>
<link href="https://cdn.shopify.com" rel="preconnect" crossorigin>

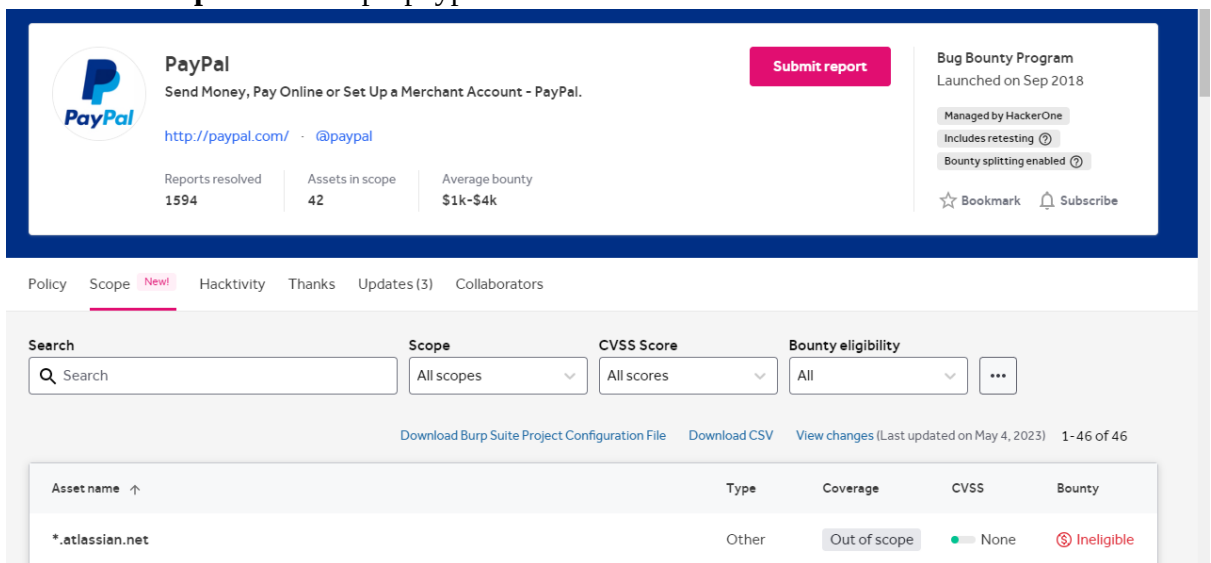
<title>Search "&#039;&quot; ns=netsparker&#40;0x004248&#41; " | Ring</title>
```

- **Proposed mitigation or fix**

1. Implement rigid input validation on user-generated material, such as form fields and URL parameters. Input validation and sanitization. Verify and clean up input to get rid of or encrypt any possibly harmful code.
2. To stop injected scripts from running, properly encrypt user-generated material before displaying it on web pages. To ensure secure rendering of user-supplied data, utilize output encoding techniques like HTML entity encoding or content security policies (CSP).
3. Implement and implement a content security policy (CSP) that limits the sources of material and scripts that are permitted to run on your web pages. By prohibiting the execution of unauthorised scripts, this lessens the impact of XSS assaults.
4. Contextual Output Validation: Perform context-specific output validation to ensure that user-generated content is appropriate for the particular output context. Different contexts may require different sanitization techniques, so be aware of where and how the data will be used.
5. Use Security Libraries and Frameworks-Employ security libraries and frameworks that offer built-in protection against XSS vulnerabilities. These tools can automatically handle input validation, output encoding, and other security measures to prevent XSS attacks.
6. Secure Development Practices: Follow secure coding practices, such as using parameterized queries or prepared statements when interacting with databases, to prevent SQL injection vulnerabilities that can be used in conjunction with XSS attacks.

Report 06

- **Vulnerability title** – Insecure HTTP Usage
- **Owsap vulnerability**- Security Misconfiguration
- **Vulnerability description** - The vulnerability known as "Insecure HTTP Usage" refers to the practice of sending sensitive data through insecure HTTP rather than secure HTTPS. It leaves data open to assault, alteration, and unauthorised access. Man-in-the-middle attacks, where attackers intercept and alter data passing between users and services, are made possible by this vulnerability. Anyone with network access has the ability to intercept sensitive information sent through unsecured HTTP. Attackers have the ability to take over sessions, take user credentials, and risk privacy.
- **Affected components** - <http://paypal.com/>



PayPal
Send Money, Pay Online or Set Up a Merchant Account - PayPal.

<http://paypal.com/> · @paypal

Reports resolved: 1594 | Assets in scope: 42 | Average bounty: \$1k-\$4k

Submit report

Bug Bounty Program
Launched on Sep 2018

Managed by HackerOne
Includes retesting
Bounty splitting enabled

☆ Bookmark | 🔔 Subscribe

Policy | Scope **New!** | Hacktivity | Thanks | Updates (3) | Collaborators

Search: | Scope: All scopes | CVSS Score: All scores | Bounty eligibility: All

[Download Burp Suite Project Configuration File](#) | [Download CSV](#) | [View changes \(Last updated on May 4, 2023\)](#) | 1-46 of 46

Asset name ↑	Type	Coverage	CVSS	Bounty
*.atlassian.net	Other	Out of scope	None	Ineligible

In this website the vulnerability is in following domain.

api.swiftfinancial.com

Web Security - IE2062

Year 2 Semester 2 - 2023

*.venmo.com	Other	In scope	Critical	Eligible
*.xoom.com	Other	In scope	Critical	Eligible
351727428 iOS Venmo App	iOS: App Store	In scope	Critical	Eligible
api.loanbuilder.com	Domain	In scope	Critical	Eligible
api.swiftfinancial.com	Domain	In scope	Critical	Eligible
braintree.com Please note braintree.com does not belong to PayPal, and as such is out of scope.	Domain	Out of scope	None	Ineligible
com.paypal.android.p2pmobile	Android: Play Store	In scope	Critical	Eligible
com.paypal.here	Android: Play Store	In scope	Critical	Eligible
com.paypal.here	iOS: App Store	In scope	Critical	Eligible

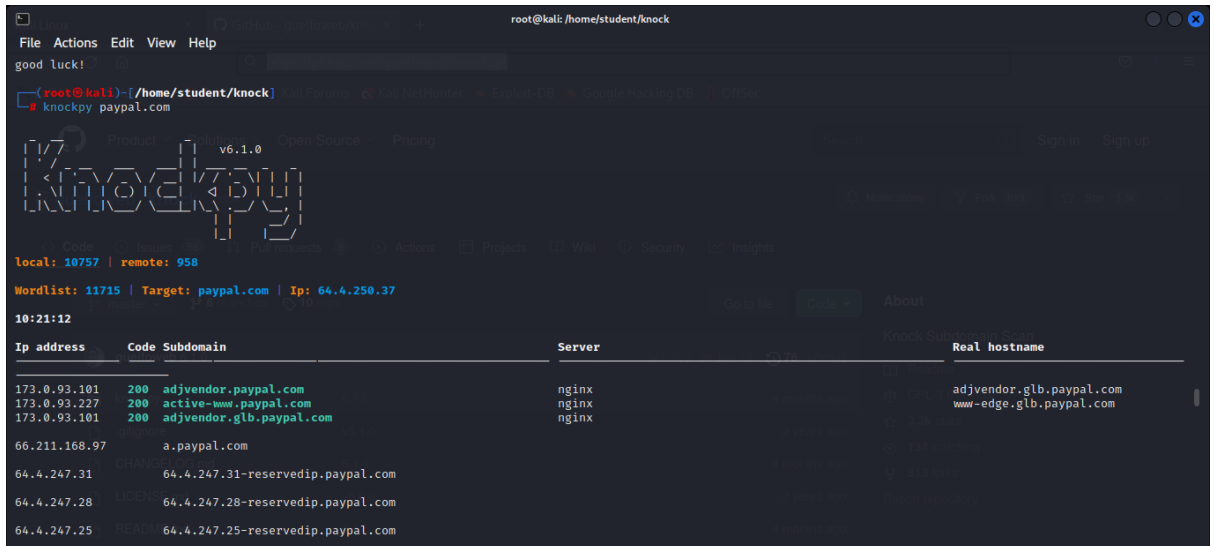
- **Impact assessment –**

1. **Data Interception:** Attackers can intercept and read sensitive data transmitted over the network via insecure HTTP. Confidential information, like login passwords, financial information, personal information, or intellectual property, may become public as a result of this.
2. **Privacy Breach:** Privacy violations might happen as a result of insufficient security precautions brought on by insecure HTTP use. Attackers can get access to and use personal information, which can result in fraud, identity theft, or unauthorised profiling.
3. **Man-in-the-Middle Attacks:** Man-in-the-middle attacks can be carried out by attackers by taking advantage of vulnerable HTTP connections. They can compromise the integrity and authenticity of communications by intercepting and manipulating data, injecting harmful material, rerouting users to phoney websites, or capturing critical information.
4. **Attacks that hijack HTTP sessions** are possible when the connection is not secure. Attackers have the ability to steal session cookies or tokens, giving them the ability to pose as genuine users, log into accounts without authorization, and carry out harmful actions.
5. **Damage to Reputation and User Trust:** Use of insecure HTTP can erode user trust and harm a company's reputation. Customers' trust and commercial possibilities may suffer as a result of users avoiding unsecure websites or applications.

Web Security - IE2062**Year 2 Semester 2 - 2023**

6. Compliance and Legal Repercussions: Using insecure HTTP might result in non-compliance with data protection laws and industry standards, putting organisations at risk of fines, litigation, or other legal action.
- **Steps to reproduce –**
 1. 1. Select the application or system: Select the system or target application you believe may be using insecure HTTP. This might be a web application, an API, or some other component that communicates via HTTP.
 2. Identify Sensitive Procedures or Data: Determine whether specific processes or data should now be delivered over secure HTTP connections . This may include login forms, money exchanges, personal information inputs, and other sensitive data transfers.
 3. Disrupt Network communication: Use the appropriate tools, such as network sniffers like Wireshark or proxy tools like Burp Suite, to intercept and record network traffic between the client and the target application or system. Verify that the tools are configured properly to record HTTP traffic.
 4. Execute the system's or an application's designated sensitive function to begin the sensitive function. provide a login form, complete a transaction, or provide personal information, for example.
 5. Monitor Network Traffic: Keep a watch on the network traffic that was acquired using the interception tool. Look for any HTTP requests and answers related to the sensitive operation you performed in the previous phase.
 6. Look for Insecure HTTP Connections: Look over the network traffic that was captured for any occasions when sensitive data or commands were being transmitted through insecure HTTP connections. Look for any URLs, headers, or other hints that suggest HTTP rather than HTTPS is being used.
 7. Document the Results: List the URLs and the specific occurrences of Insecure HTTP Usage

- Proof of concept (if applicable)



1. Insecure HTTP Usage

MEDIUM 1

Netsparker identified that the target website allows web browsers to access to the website over HTTP and doesn't redirect them to HTTPS.

HSTS is implemented in the target website however HTTP requests are not redirected to HTTPS. This decreases the value of HSTS implementation significantly.

For example visitors who haven't visited the HTTPS version of the website previously will not be able to take advantage of HSTS.

Impact

Users will not be able to take advantage of HSTS which almost renders the HSTS implementation useless. Not having HSTS will make MITM attacks easier for attackers.

If there is a client side redirect to HTTPS version of the website (via JavaScript or Meta tags) then you can ignore this vulnerability.

Vulnerabilities

1.1. <http://api.swiftfinancial.com/>

Web Security - IE2062**Year 2 Semester 2 - 2023**

- **Proposed mitigation or fix-**

1. Get an SSL/TLS certificate and set up the server to allow HTTPS to enable HTTPS. By ensuring that all conversations are encrypted, data confidentiality is preserved.
2. Implement HTTP-to-HTTPS redirection so that any attempts to visit the website through plain HTTP are immediately sent to the more secure HTTPS version.
3. Update all links and references on website or application to point to HTTPS URLs. This includes any embedded material as well as internal and external references. Any hardcoded HTTP URLs should be updated to utilize HTTPS.
4. Use Secure Cookies: To ensure that cookies are only transferred over secure HTTPS connections, set the "Secure" mark on each cookie.
5. HSTS (HTTP Strict Transport Security): Set up HSTS headers on the server to tell browsers to always communicate with the website via HTTPS. This lowers the possibility that people will access the site using insecure HTTP.
6. Cross-site scripting (XSS) attacks and other content-related vulnerabilities can be reduced by using Content Security Policy (CSP) headers.
7. Regular Security Audits: Conduct routine security audits and vulnerability assessments to spot and immediately fix any possible security flaws.
8. Users should be made more knowledgeable of the dangers of using unsecured HTTP and the value of safe surfing practises. Before providing sensitive information, remind them to look for the lock icon and "https://" in the URL.

Report 07

- **Vulnerability title** - SSL/TLS Not Implemented
- **Owsap Vulnerability**- Security Misconfiguration
- **Vulnerability description** - A major security method used to create encrypted and secure communication channels over the internet is the SSL/TLS (Secure Sockets Layer/Transport Layer Security) protocol. However, the "SSL/TLS Not Implemented" vulnerability describes a circumstance in which a web application or service improperly implements SSL/TLS, leaving client and server interactions open to eavesdropping and manipulation.

Without SSL/TLS, sensitive data being sent between the client's browser and the server, such as login passwords, financial data, or personal information, might be intercepted by hackers. Users are at danger of identity theft, data breaches, and unauthorised access to their sensitive information as a result of this.

- **Affected components** – <http://kkcr.com/>

Here is the scope.

Web Security - IE2062
Year 2 Semester 2 - 2023

[Download Burp Suite Project Configuration File](#)
[Download CSV](#)
[View changes \(Last updated on April 18, 2023\)](#)
1-9 of 9

Asset name ↑	Type	Coverage	CVSS	Bounty
*.kkcr.cloud	Other	In scope	Critical	Ineligible
*.kkcr.com	Other	In scope	Critical	Ineligible
kkcr.com	Domain	In scope	Critical	Ineligible
portal.kkcr.com	Domain	In scope	Critical	Ineligible
processaccess.kkcr.com	Domain	In scope	Critical	Ineligible
www.fskkradvisor.com	Domain	In scope	Critical	Ineligible
www.kkresg.com	Domain	In scope	Critical	Ineligible
www.kkrfunds.com	Domain	In scope	Critical	Ineligible
www.kkresg.com	Domain	In scope	Critical	Ineligible

- **Impact assessment –**

1. Data interception: Without SSL/TLS encryption, hackers might possibly compromise data by intercepting sensitive information being sent between users and the server.
2. Man-in-the-Middle Attacks: Attackers can place themselves in the middle of a communication channel between a client and a server, intercepting and modifying unencrypted data packets that they can then change or inject with malicious code.
3. Credential Theft: Attackers may intercept usernames, passwords, and other authentication credentials sent without SSL/TLS encryption, giving them access to user accounts.
4. Privacy Breach: Without SSL/TLS, user communications are susceptible to monitoring, compromising privacy, and perhaps infringing on data protection laws.
5. Damage to Reputation: Poor SSL/TLS implementation can erode user confidence and harm a company's or service provider's reputation.

- **Steps to reproduce –**

Web Security - IE2062**Year 2 Semester 2 - 2023**

1. Check to see if the website's URL begins with "https://" rather than "http://" to confirm if it is using HTTPS. The usage of SSL/TLS encryption is indicated by the presence of "https://".
 2. Search for a padlock icon in the URL bar or close to the browser window. A padlock indicates that the connection is safe and that the website has a valid SSL/TLS certificate.
 3. Certificate Information: To examine the SSL/TLS certificate information, click on the padlock symbol or the HTTPS indication in the address bar. Make that the certificate matches the website domain and was issued by a reputable certificate authority.
 4. Validity of Certificate: Verify the SSL/TLS certificate's duration of validity. Verify that it is not expired or about to expire. Potential security hazards may be indicated by an expired certificate.
 5. Certificate faults: Any certificate warnings or faults that the browser shows might be a sign of possible security problems. Any error warnings should be noted, and you may want to ask the website owner for more information.
 6. Use online tools that scan and examine a website's SSL/TLS implementation, such as SSL/TLS checkers. These tools can offer comprehensive details on the available protocols, SSL/TLS settings, and any vulnerabilities.
 7. The SSL Server Test and Qualys SSL Server Test from SSL Labs (<https://www.ssllabs.com/ssltest>) are two common online SSL/TLS verification tools.
- **Proof of concept (if applicable) –**

1. SSL/TLS Not Implemented

MEDIUM 1

Netsparker detected that SSL/TLS is not implemented.

Impact

An attacker who is able to intercept your - or your users' - network traffic can read and modify any messages that are exchanged with your server.

That means that an attacker can see passwords in clear text, modify the appearance of your website, redirect the user to other web pages or steal session information.

Therefore no message you send to the server remains confidential.

Vulnerabilities

1.1. <https://kkr.com/>

- **Proposed mitigation or fix-**

Enable SSL/TLS: Set up web servers to provide secure HTTPS connections for all communication by implementing SSL/TLS on them.

Obtain respected SSL/TLS Certificate Authorities: To ensure safe and authenticated communications, get dependable SSL/TLS certificates from respected certificate authorities.

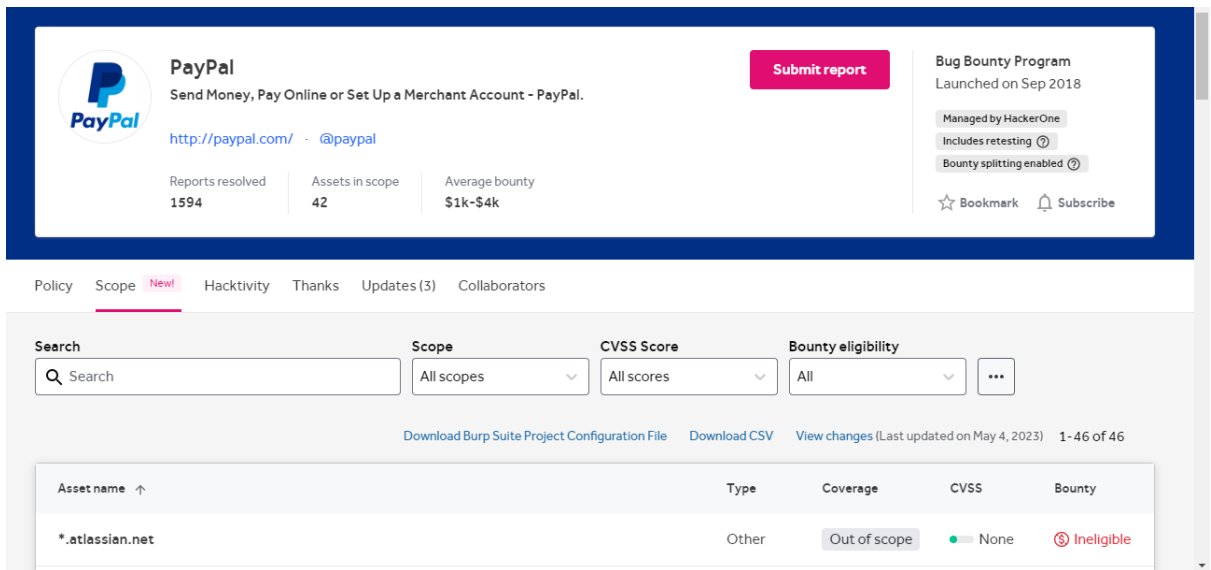
Automated HTTP to HTTPS redirection should be used to make sure that all users are connecting securely.

Make use of secure SSL/TLS configurations: Use recommended configurations to set up SSL/TLS with powerful cypher suites, secure protocols, and effective certificate management.

Update SSL/TLS libraries on a regular basis to ensure that they are using the most recent security fixes and vendor recommendations.

Report 08

- **Vulnerability title** - Source Code Disclosure
- **Owsap vulnerability**- Security Misconfiguration
- **Vulnerability description** – This vulnerability is when the source code of a web application or component of software is unintentionally made available to the public or exposed to unauthorised parties. The application's internal workings, algorithms, and potentially sensitive data are all detailed in the source code. When source code is made public, it invites attackers to examine it carefully, find flaws, and carry out specialised assaults. A source code leak can have serious consequences, such as unauthorised data access, theft of intellectual property, compromising of encryption techniques, and exposing of confidential business logic.
- **Affected components** – <http://paypal.com/>



Asset name ↑	Type	Coverage	CVSS	Bounty
*.atlassian.net	Other	Out of scope	None	Ineligible

www.swiftcapital.com This is the domain that I scanned.

Web Security - IE2062

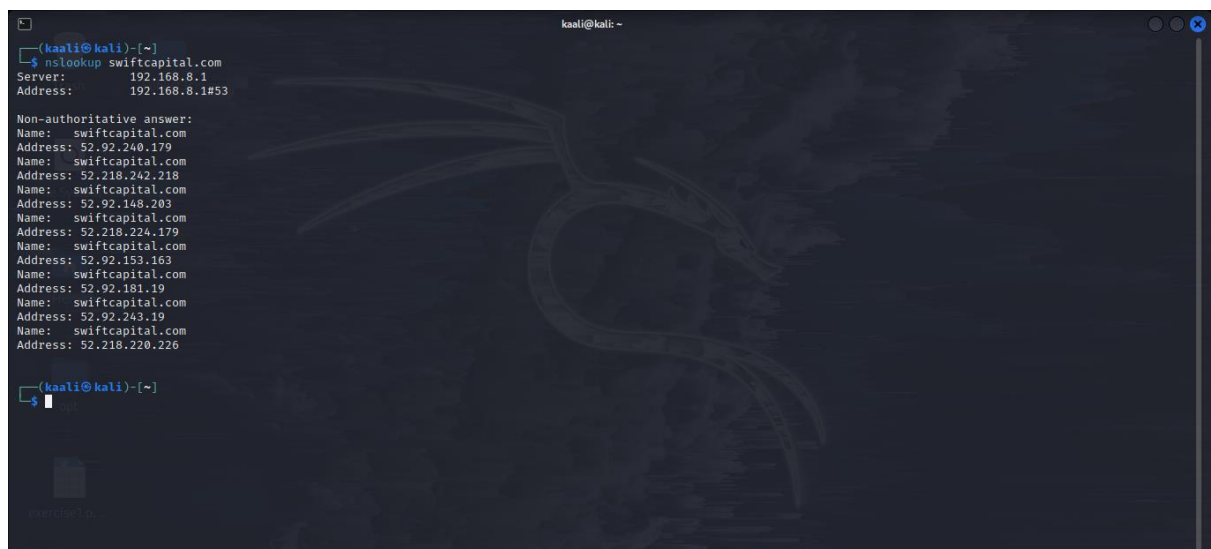
Year 2 Semester 2 - 2023

swiftnfinancial.com	Domain	In scope	Critical	Eligible
www.gopay.com Please submit all Gopay reports to: • Paypal.vulbox.com	Domain	Out of scope	None	Ineligible
www.loanbuilder.com	Domain	In scope	Critical	Eligible
www.paypal-*.com PayPal's Partner Sites (www.paypal-*.com) are mainly marketing based sites that are not part of the core PayPal customer domains (paypal.com) and are managed by hosting vendor companies. They have variable timelines and are often decommissioned. A listing of these sites designated for deprecation will not be publicly maintained due to frequent changes. When researching bugs on these sites, please keep this in mind as bug Submissions for sites on schedule for deprecation will not be honored. Submissions of bugs relating to services or domains not referenced above or for sites on schedule for deprecation are ineligible for the Bug Bounty Program and will not be eligible for a Bounty Payment.	Other	In scope	Critical	Eligible
www.swiftcapital.com	Domain	In scope	Critical	Eligible
www.swiftfinancial.com	Domain	In scope	Critical	Eligible

- Impact assessment** - Source code disclosure vulnerability can have significant impacts on application security. Attackers might take advantage of vulnerabilities in the accessible source code, resulting in data breaches and unauthorised access. When confidential business logic and proprietary algorithms are made public, intellectual property theft becomes a concern. It is possible to compromise security measures, which raises the possibility of successful assaults. It becomes easier to launch targeted assaults that focus on certain flaws, and regulatory compliance may be compromised. Furthermore, it becomes difficult to fix vulnerabilities, allowing attackers to take advantage of known flaws. Organizations must prioritize secure coding practises, limit source code access, carry out frequent security audits, and handle sensitive data with care to lessen these effects. This secure intellectual property, uphold compliance, prevent unauthorised access, and improve overall application security.
- Steps to reproduce –**
 1. **Reconnaissance:** Become familiar with the target web application's hosting environment, technological stack, and framework. Passive information collecting techniques, such as web crawling, searching via public code repositories, or examining freely available material, can be used to do this.
 2. **Find potential access points:** Look for common setup issues or well-known attack paths that might reveal the source code. Examples include improperly setup web servers, directory listing problems, hazardous backup files, and publicly accessible development environments.
 3. **Manual inspection:** Check the URLs, file locations, and response headers of the web application for any indications of source code exposure. Look for URLs or directory paths pointing to the source code-containing files or folders.

Web Security - IE2062**Year 2 Semester 2 - 2023**

4. Directory traversal: Attempt to access directories or files outside of the web application's intended directory structure by manipulating URL parameters or taking advantage of directory traversal flaws. This approach aims to access files that are not intended for widespread use.
 5. Debug information and error messages: In the web application, use trigger error conditions to check for any error messages or debug information that may reveal source code fragments. Send false requests, manipulate input to create errors, and search for any leak of confidential information.
 6. Source code repositories: Check for any potential configuration errors or unintended disclosure of sensitive files or credentials if the web application's source code is stored in a version control system or public code repository.
- **Proof of concept (if applicable) –**

Nslookup

```
kaali@kali: ~  
(kaali@kali)~  
$ nslookup swiftcapital.com  
Server:      192.168.8.1  
Address:     192.168.8.1#53  
  
Non-authoritative answer:  
Name:   swiftcapital.com  
Address: 52.92.240.179  
Name:   swiftcapital.com  
Address: 52.218.242.218  
Name:   swiftcapital.com  
Address: 52.92.148.203  
Name:   swiftcapital.com  
Address: 52.218.224.179  
Name:   swiftcapital.com  
Address: 52.92.153.163  
Name:   swiftcapital.com  
Address: 52.92.181.19  
Name:   swiftcapital.com  
Address: 52.92.243.19  
Name:   swiftcapital.com  
Address: 52.218.220.226  
  
(kaali@kali)~  
$
```

1. [Possible] Source Code Disclosure (Generic)

MEDIUM  **1**

Netsparker identified a possible source code disclosure (Generic).

An attacker can obtain server-side source code of the web application, which can contain sensitive data - such as database connection strings, usernames and passwords - along with the technical and business logic of the application.

Impact

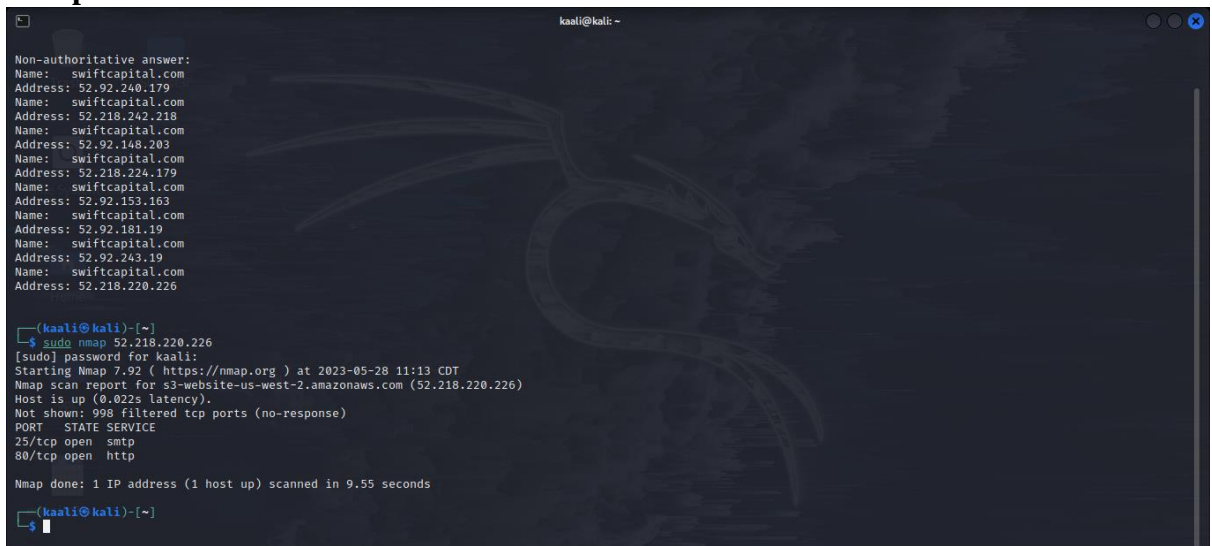
Depending on the source code, database connection strings, username and passwords, the internal workings and business logic of the application might be revealed. With such information, an attacker can mount the following types of attacks:

- Access the database or other data resources. Depending on the privileges of the account obtained from the source code, it may be possible to read, update or delete arbitrary data from the database.
- Gain access to password protected administrative mechanisms such as dashboards, management consoles and admin panels, hence gaining full control of the application.
- Develop further attacks by investigating the source code for input validation errors and logic vulnerabilities.

Vulnerabilities

1.1. <https://www.swiftcapital.com/?hTTp://r87.com/n>

Nmap



```
Non-authoritative answer:
Name: swiftcapital.com
Address: 52.92.240.179
Name: swiftcapital.com
Address: 52.218.242.218
Name: swiftcapital.com
Address: 52.92.148.203
Name: swiftcapital.com
Address: 52.218.224.179
Name: swiftcapital.com
Address: 52.92.153.163
Name: swiftcapital.com
Address: 52.92.181.19
Name: swiftcapital.com
Address: 52.92.243.19
Name: swiftcapital.com
Address: 52.218.220.226

(kaali@kali)-[~]
└─$ sudo nmap 52.218.220.226
[sudo] password for kaali:
Starting Nmap 7.92 ( https://nmap.org ) at 2023-05-28 11:13 CDT
Nmap scan report for s3-website-us-west-2.amazonaws.com (52.218.220.226)
Host is up (0.022s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 9.55 seconds

(kaali@kali)-[~]
└─$
```

• Proposed mitigation or fix-

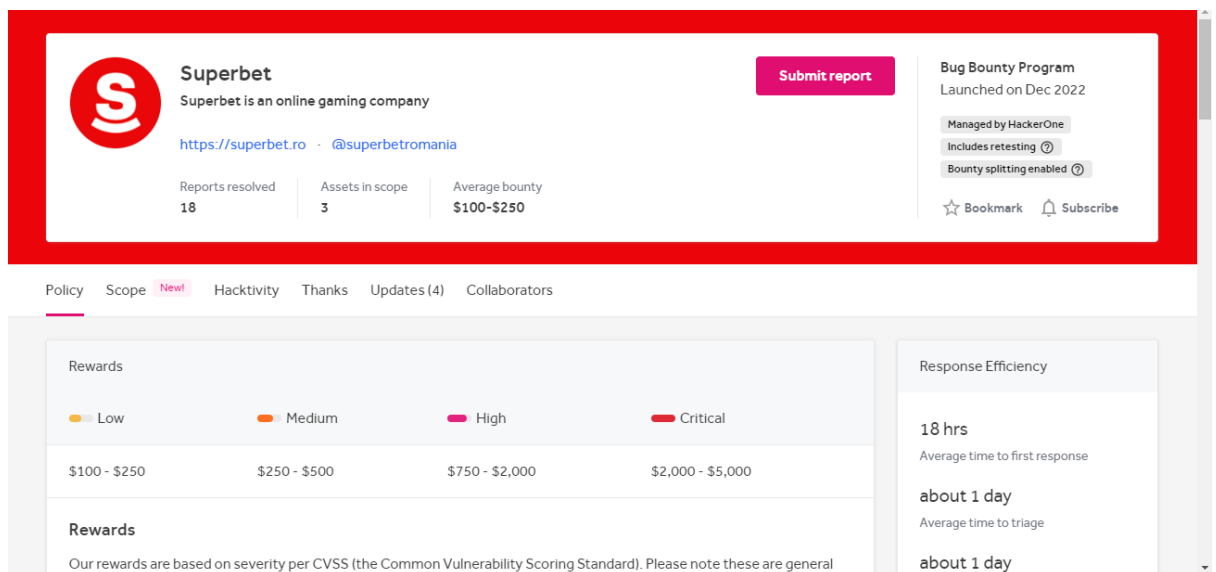
1. Source code repositories should be appropriately protected with robust access restrictions, including authentication and permission procedures. Ensure that only authorized personnel have access.

Web Security - IE2062**Year 2 Semester 2 - 2023**

2. Use safe Development Practises: To avoid typical vulnerabilities like injection attacks, use safe coding techniques like input validation, output encoding, and parameterized queries.
3. Maintain all software, libraries, frameworks, and development tools up to date with the most recent security updates by regularly patching and updating them. This assists in avoiding known vulnerabilities that may result in the source code's exposure.
4. Implement access controls by setting up secure server configurations and appropriate file permissions to limit access to sensitive folders or files that include the source code. Access must only be granted to those who truly need it, according to the least privilege principle.
5. Error handling and logging: Handle error messages correctly to prevent disclosing private information or programme internals. Implement thorough logging techniques to keep an eye on and spot any suspicious source code-related activity.
6. Security Audits: Perform routine security audits and code reviews to find and fix any possible flaws or dangers in the source code. This aids in finding problems and resolving them before they may be exploited.
7. Employee Education and Awareness: Inform developers and staff of the significance of source code security and the possible threats.

Report 09

- **Vulnerability title** - ROBOT Attack Detected (Strong Oracle)
- **Owsap vulnerability**- XML external entities
- **Vulnerability description** - The "ROBOT Attack Detected (Strong Oracle) vulnerability" is a security flaw that targets RSA encryption used in SSL/TLS protocols. It enables hackers to use servers' error messages to decrypt sensitive data. An attacker can use the error messages received after sending bad ciphertexts to a server that is open to attack to progressively figure out the private key. Passwords and other intercepted data are then decrypted using this key. Many popular SSL/TLS implementations are impacted by the flaw, which puts the security of many websites and services at risk
- **Affected components** - <https://superbet.ro/>



The screenshot shows the Superbet Bug Bounty Program page. At the top, there's a header with the Superbet logo, a 'Submit report' button, and program details: 'Bug Bounty Program Launched on Dec 2022', 'Managed by HackerOne', 'Includes retesting', and 'Bounty splitting enabled'. Below this, a table shows 'Reports resolved: 18', 'Assets in scope: 3', and 'Average bounty: \$100-\$250'. A navigation bar includes links for Policy, Scope, Hacktivity, Thanks, Updates (4), and Collaborators. The main content area features a 'Rewards' table and a 'Response Efficiency' section.

Rewards			
Low	Medium	High	Critical
\$100 - \$250	\$250 - \$500	\$750 - \$2,000	\$2,000 - \$5,000

Rewards
Our rewards are based on severity per CVSS (the Common Vulnerability Scoring Standard). Please note these are general

Response Efficiency

18 hrs
Average time to first response

about 1 day
Average time to triage

about 1 day

- **Impact assessment** - Significant effects are caused by the ROBOT Attack Detected (Strong Oracle) vulnerability. It enables attackers to decrypt sensitive data exchanged across a network, like as passwords. Identity theft, financial loss, and unauthorized access to accounts may follow from this. By enabling attackers to listen in on

Web Security - IE2062**Year 2 Semester 2 - 2023**

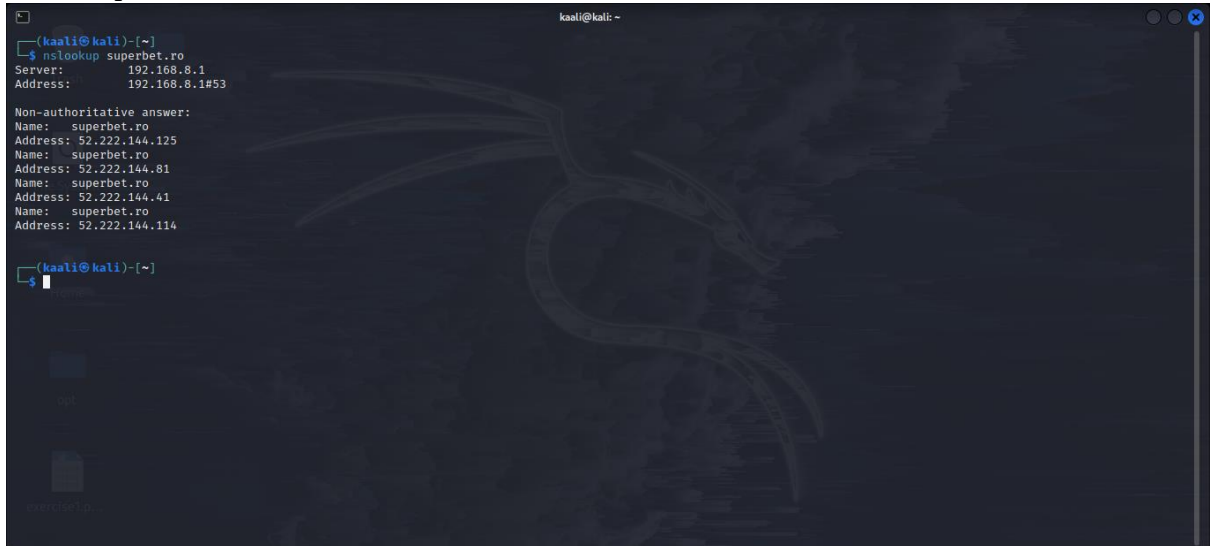
communications, it also compromises their privacy. Numerous commonly used SSL/TLS implementations are impacted, posing a danger to several websites and online services. Data breaches and a loss of trust in secure transactions can occur.

- **Steps to reproduce –**

1. **Select a Target Website:** Select a target website that supports and makes use of RSA-based cypher suites. This bug specifically targets RSA-based encryption.
2. **Gather Encrypted Communication Data:** Compile the data received via encrypted communication between the attacker's client and the intended target website. This may be done by utilizing tools like Wireshark or tcpdump to intercept network traffic.
3. **Extract Encrypted RSA Messages:** Look through the recorded network traffic to identify the encrypted RSA messages that were sent back and forth between the client and the server. Find out which RSA cypher suites are being utilised for communications during the RSA handshake.
4. **Unlock RSA communications** using a decryption programme or script. RSA communications were gathered and need to be unlocked.
5. **Examine the Plaintext Messages:** Analyze the decrypted RSA messages and check for any possible security gaps. Look for situations where the server accepts incorrect RSA ciphertexts but provides a different response depending on how the ciphertext adding is authorized.
6. **Create Custom RSA Messages:** Starting with the discovered vulnerability, develop one-of-a-kind RSA messages that exploit the server's inability to handle RSA ciphertexts that are not authentic. These carefully crafted messages should be sent with the goal of collecting sensitive information or infiltrating the target system.
7. **Sending the target website,** the constructed RSA messages allow you to mimic a client-server connection.
8. **Watch Response:** Monitor the server's response to the generated RSA messages. If the vulnerability is present and is successfully exploited, the server's response may provide access to sensitive data or allow illegal activity.

- **Proof of concept (if applicable)**

Nslookup



```
kaali@kali: ~  
$ nslookup superbet.ro  
Server:      192.168.8.1  
Address:     192.168.8.1#53  
  
Non-authoritative answer:  
Name:   superbet.ro  
Address: 52.222.144.125  
Name:   superbet.ro  
Address: 52.222.144.81  
Name:   superbet.ro  
Address: 52.222.144.41  
Name:   superbet.ro  
Address: 52.222.144.114  
  
kaali@kali: ~  
$
```

Here is the scanned Netsparker report.

1. ROBOT Attack Detected (Strong Oracle)

HIGH 1

Netsparker identified the ROBOT (Return Of Bleichenbacher's Oracle Threat) vulnerability in the target web server. The ROBOT vulnerability allows anyone on the Internet to perform RSA decryption and signing operations with the private key of a TLS server. Expression, *Strong Oracle*, means that the attack is possible by collecting less than a million packets.

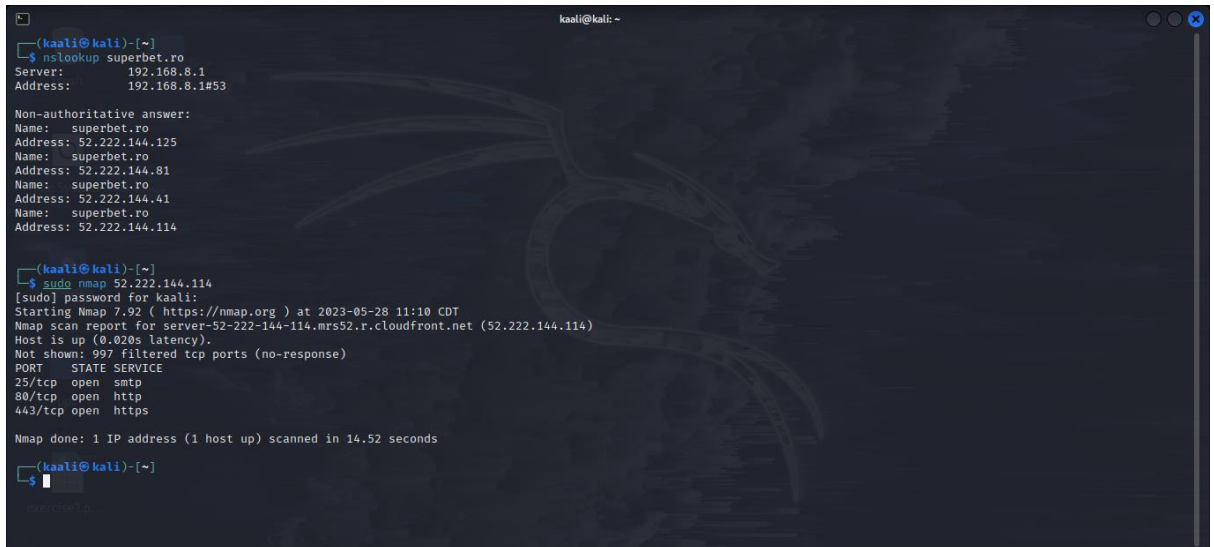
Impact

An attacker can passively record the traffic and later on decrypt it. Even though forward secrecy is enabled, the risk depends on how fast an attacker is able to perform the attack. Also, a server impersonation or a man-in-the-middle attack is possible.

Vulnerabilities

1.1. <https://superbet.ro/>

Nmap



```
(kali@kali)~$ nslookup superbet.ro
Server:      192.168.8.1
Address:     192.168.8.1#53

Non-authoritative answer:
Name:   superbet.ro
Address: 52.222.144.125
Name:   superbet.ro
Address: 52.222.144.81
Name:   superbet.ro
Address: 52.222.144.41
Name:   superbet.ro
Address: 52.222.144.114

(kali@kali)~$ sudo nmap 52.222.144.114
[sudo] password for kali:
Starting Nmap 7.92 ( https://nmap.org ) at 2023-05-28 11:10 CDT
Nmap Scan report for server-52-222-144-114.mrs52.r.cloudfront.net (52.222.144.114)
Host is up (0.020s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 14.52 seconds

(kali@kali)~$
```

- **Proposed mitigation or fix**

1. **Update SSL/TLS implementations:** Update the versions which are against the ROBOT vulnerability. Check with your software or service provider for the latest patches or updates specifically addressing this vulnerability.
2. **Deactivate RSA Encryption:** In SSL/TLS settings, if at all feasible, deactivate the RSA encryption cypher suites. Instead, give priority to using cutting-edge encryption techniques like Perfect Forward Secrecy (PFS) and Elliptic Curve Cryptography (ECC).
3. **Implement Server-Side Fixes:** To address the issue, implement any server-side patches or fixes that your programme or service provider may have given. These remedies can need modifying the underlying code or settings to stop sensitive information from being revealed through error messages.
4. **Monitor for Attacks:** Constantly keep an eye on system logs and network data for any strange activity or possible ROBOT attack attempts. Such assaults can be detected and mitigated with the use of intrusion detection and prevention systems.
5. **Stay Informed:** Keep abreast on security alerts and news from reliable sources. Observe the recommendations made by vendors and security professionals on the best methods for safeguarding SSL/TLS implementations.
6. **Use Strong Cryptographic Practises:** Follow to accepted best practises for managing cryptographic keys, such as employing strong and distinctive private keys and

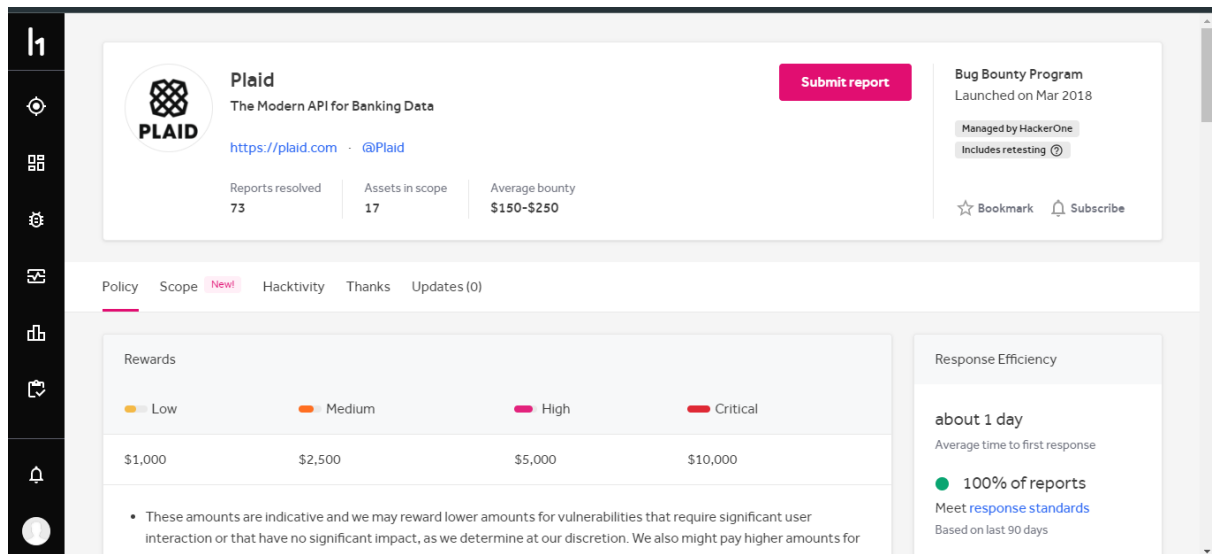
Web Security - IE2062**Year 2 Semester 2 - 2023**

certificates, rotating keys on a regular basis, and safely storing sensitive cryptographic data.

7. Conduct frequent penetration tests and security assessments to find and fix any flaws or incorrect configurations in your SSL/TLS implementations.

Report 10

- **Vulnerability title:** Missing X-Frame-Options header
(Security Misconfiguration)
- **Vulnerability description:** Missing X-Frame-Options header which means that this website could be at risk of a clickjacking attack. The X-Frame-OptionsHTTP header field indicates a policy that specifies whether the browser should render the transmitted resource within a frame or an iframe. Servers can declare this policy in the header of their HTTP responses to prevent clickjacking attacks, which ensures that their content is not embedded into other pages or frames.
- **Affected components:** <https://plaid.com/>



The screenshot shows the Plaid Bug Bounty Program page. At the top, there's a header with the Plaid logo, the text "The Modern API for Banking Data", and a "Submit report" button. Below this, there's a section with statistics: "Reports resolved 73", "Assets in scope 17", and "Average bounty \$150-\$250". To the right, it says "Bug Bounty Program Launched on Mar 2018", "Managed by HackerOne", and "Includes retesting". There are also "Bookmark" and "Subscribe" links.

Below the header, there's a navigation bar with tabs: "Policy", "Scope", "New!", "Hacktivity", "Thanks", and "Updates (0)". The "New!" tab is currently selected.

The main content area is divided into two sections. The left section is titled "Rewards" and shows a table with four columns: "Low", "Medium", "High", and "Critical". The corresponding reward amounts are \$1,000, \$2,500, \$5,000, and \$10,000 respectively. Below the table, there's a note: "These amounts are indicative and we may reward lower amounts for vulnerabilities that require significant user interaction or that have no significant impact, as we determine at our discretion. We also might pay higher amounts for..."

The right section is titled "Response Efficiency" and shows "about 1 day" as the average time to first response. It also states "100% of reports Meet response standards" and "Based on last 90 days".

Here are the domains which are in scope

Download Burp Suite Project Configuration File Download CSV View changes (Last updated on March 15, 2023) 1 - 17 of 17				
Asset name ↑	Type	Coverage	CVSS	Bounty
api.blockscore.com	Domain	In scope	Critical	Eligible
app.quovo.com	Domain	In scope	Critical	Eligible
cdn.plaid.com This is on Amazon CloudFront, so the scope here is limited to our content and configuration issues.	Domain	In scope	Critical	Eligible
dashboard.plaid.com Plaid's developer dashboard	Domain	In scope	Critical	Eligible
demo.plaid.com Demo Plaid developer integration	Domain	In scope	Medium	Eligible
https://github.com/plaid/plaid-link-android Plaid's drop-in client-side module for authentication. Available for web, mobile web and iOS.	Source code	In scope	Critical	Eligible
https://github.com/plaid/plaid-link-examples Plaid's drop-in client-side module for authentication. Available for web, mobile web and iOS.	Source code	In scope	Critical	Eligible
https://github.com/plaid/plaid-link-ios	Source code	In scope	Critical	Eligible

- **Impact assessment:** Clickjacking is when an attacker uses multiple transparent or opaque layers to trick a user into clicking on a button or link on a framed page when they were intending to click on the top-level page. Thus, the attacker is "hijacking" clicks meant for their page and routing them to other another page, most likely owned by another application, domain, or both. Using a similar technique, keystrokes can also be hijacked. With a carefully crafted combination of stylesheets, iframes, and text boxes, a user can be led to believe they are typing in the password to their email or bank account, but are instead typing into an invisible frame controlled by the attacker

- **Steps to reproduce**

Here I found a vulnerability in this site that attackers are able to do Clickjacking.

Firstly, I took a site which is not vulnerable for missing X-frame options.

I took amazon.com.

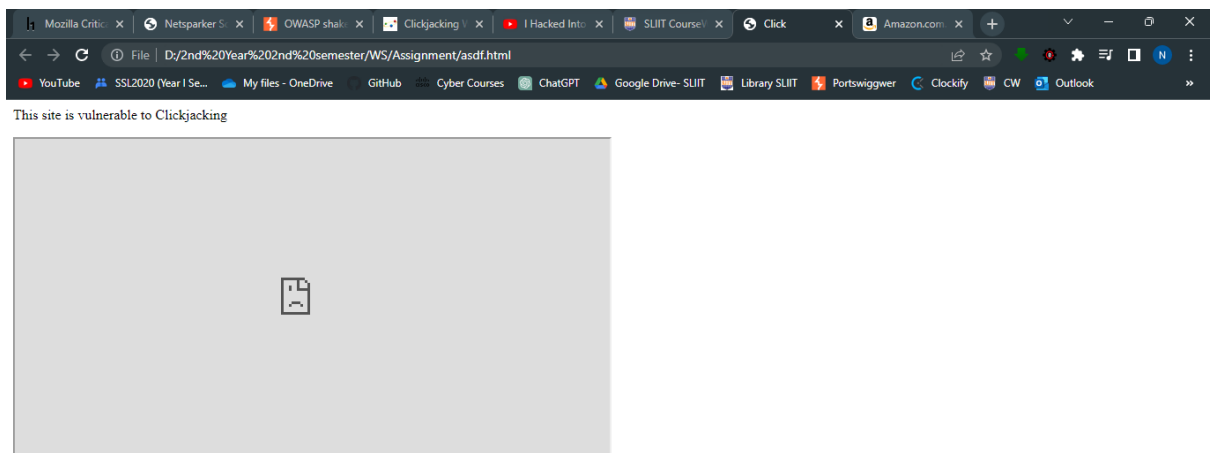
Web Security - IE2062**Year 2 Semester 2 - 2023**

Created a html page and added iframe and pasted the link there.

Here is the code I used for that.

```
<head>
  <title>Click</title>
</head>
<body>
  <p>This site is vulnerable to Clickjacking</p>
  <iframe src = "https://www.amazon.com/" width=50% height=60%/>
</body>
```

The web page was shown as below. The amazon site refused to connect.



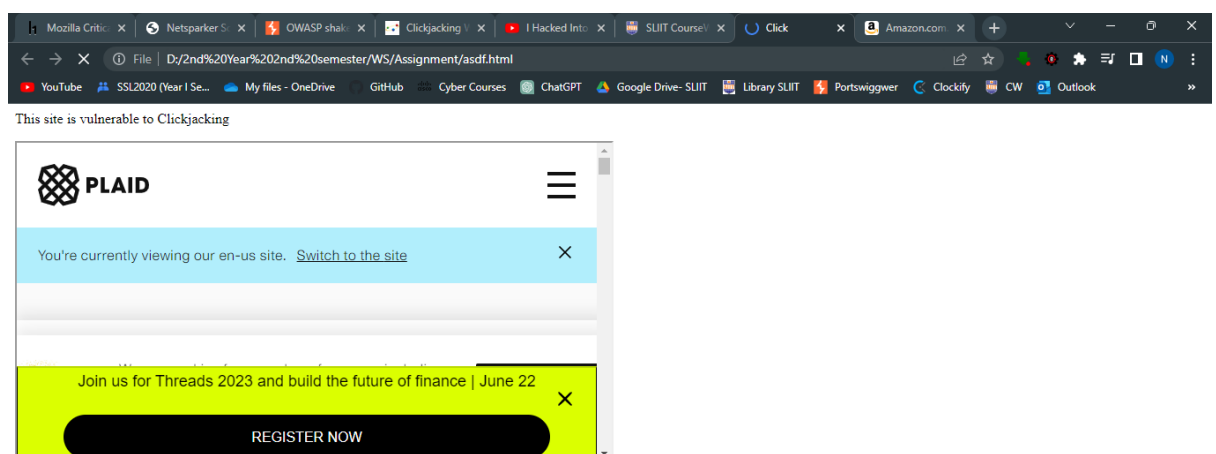
Then I did the same to this vulnerable site <https://plaid.com/>.

Here are the proofs.

Web Security - IE2062**Year 2 Semester 2 - 2023**

```
<head>
  <title>Click</title>
</head>
<body>
  <p>This site is vulnerable to Clickjacking</p>
  <iframe src = "https://plaid.com/" width=50% height=60%/>
</body>
```

I was able to connect with site by Clickjacking.



Web Security - IE2062

Year 2 Semester 2 - 2023

- **Proof of concept (if applicable):**

Here is the knockpy scan results

```

kaali@kali: ~
v6.1.0
Knockpy

Local: 10757 | remote: 153
Wordlist: 10910 | Target: plaid.com | Ip: 52.84.45.24
16:03:34

```

Ip address	Code	Subdomain	Server	Real hostname
3.93.214.11	404	analytics.plaid.com	nginx	
204.236.225.207	404	api.dashboard.plaid.com		
3.212.238.215	404	api.hosted.plaid.com		
23.23.81.121	404	api.hosted-sandbox.plaid.com		
34.206.251.153	404	api.hosted-development.plaid.com		
10.0.252.109		apidb.plaid.com		
10.105.19.190		api-v2-testing.plaid.com		
10.105.2.208		api.my-testing.plaid.com		

Nslookup

```

kaali@kali: ~
(kaali@kali)-[~]
$ nslookup plaid.com
Server:      192.168.8.1
Address:     192.168.8.1#53

Non-authoritative answer:
Name:   plaid.com
Address: 52.84.45.9
Name:   plaid.com
Address: 52.84.45.24
Name:   plaid.com
Address: 52.84.45.79
Name:   plaid.com
Address: 52.84.45.42

```

Web Security - IE2062

Year 2 Semester 2 - 2023

Nmap

```

kaali@kali: ~
Address: 52.84.45.9
Name: plaid.com
Address: 52.84.45.24
Name: plaid.com
Address: 52.84.45.79
Name: plaid.com
Address: 52.84.45.42
;; connection timed out; no servers could be reached

(kaali@kali)-[~]
$ nslookup 52.84.45.42
;; connection timed out; no servers could be reached

(kaali@kali)-[~]
$ sudo nmap 52.84.45.42
[sudo] password for kaali:
Sorry, try again.
[sudo] password for kaali:
Starting Nmap 7.92 ( https://nmap.org ) at 2023-05-28 11:07 CDT
Nmap scan report for 52.84.45.42
Host is up (0.094s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 46.55 seconds

(kaali@kali)-[~]
$

```

Here is the screenshot of nikto

[illegible]

Here are the screenshots of Netsparker report.

7. Missing X-Frame-Options Header

LOW  1

Netsparker detected a missing X-Frame-Options header which means that this website could be at risk of a clickjacking attack.

The X-Frame-Options HTTP header field indicates a policy that specifies whether the browser should render the transmitted resource within a frame or an iframe. Servers can declare this policy in the header of their HTTP responses to prevent clickjacking attacks, which ensures that their content is not embedded into other pages or frames.

Vulnerabilities

7.1. <https://plaid.com/>

Certainty



Request

```
GET / HTTP/1.1
Host: plaid.com
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Encoding: gzip, deflate
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/70.0.3538.77 Safari/537.36
X-Scanner: Netsparker
```

Response

Response Time (ms) : 1076.8282 Total Bytes Received : 163241 Body Length : 162516 Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: locale=%7B%22localeCode%22%3A%22en-us%22%2C%22countryRegionName%22%3A%22Western%20Province%22%2C%22intrinsicLocale%22%3A%22na%22%7D; Domain=plaid.com; Path=/
Server: AmazonS3
X-Cache: Miss from cloudfront
Connection: keep-alive
Via: 1.1 d14b1425e1938e6a7b583f77205097f0.cloudfront.net (CloudFront)
Content-Encoding:
Last-Modified: Fri, 19 May 2023 18:28:50 GMT
X-Amz-Cf-Pop: MRS52-P1
Vary: Accept-Encoding
Strict-Transport-Security: max-age=63072000; includeSubDomains; preload
Content-Type: text/html
Transfer-Encoding: chunked
X-Amz-Cf-Id: f1QpRouvc7zc2eJnv-21XmZ_-VVHyIIXEZQlnJUF0rgz3f9UC8DTug==
Date: Sat, 20 May 2023 00:38:39 GMT
ETag: W/"9d23a6e4b5626c2e1f4dfc092c6dd563"

<!DOCTYPE html><html class="no-js" lang="en"><head><meta charset="utf-8"/><meta http-equiv="x-ua-compatible" content="ie=edge"/><meta name="viewport" content="width=device-width, initial-scale=1.0"/><meta name="msapplication-TileColor" content="#da532c"/><meta name="theme-color" content="ffffff"/><link rel="canonical" href="https://plaid.com/"><link rel="apple-touch-icon" sizes="180x180" href="/assets/img/favicons/apple-touch-icon.png"/><link rel="icon" type="image/png" sizes="32x32" href="/assets/img/favicons/favicon-32x32.png"/><link rel="icon" type="image/png" sizes="16x16" href="/assets/img/favicons/favicon-16x16.png"/><link rel="manifest" href="/assets/img/favicons/site.webmanifest"/><link rel="mask-icon" href="/assets/img/favicons/safari-pinned-tab.svg" color="#5bbad5"/><title>Plaid: Enabling all companies to build fintech solutions</title><meta name="description" content="Plaid helps all companies build fintech solutions by making it easy, safe and reliable for people to connect their financial data to apps and services."/><meta property="og:title" content="Plaid: Enabling all companies to build fintech solutions"/><meta property="og:site_name" content="Plaid"/><meta property="og:description" content="Plaid helps all companies build fintech solutions"/></head><body></body></html>
```

- **Proposed mitigation or fix:**

1. Understand Clickjacking –
2. Implement Frame Busting - Frame killing is a method for preventing clickjacking attacks, commonly referred to as frame busting. It involves including an insignificant bit of code that checks website pages to see if an iframe or frame is being used to load pages.

Web Security - IE2062**Year 2 Semester 2 - 2023**

3. Set the X-Frame-Options Header- By setting the X-Frame-Options header in the web server's response, users can further reduce clickjacking.
4. Use Content Security Policy (CSP)
5. Keep Your Software Up to Date
6. Educate Users and Promote Awareness